La seguridad en redes. Control de accesos. Técnicas criptográficas. Mecanismos de firma digital. Control de Intrusiones. Cortafuegos. Medidas específicas para las comunicaciones móviles

ÍNDICE

1 INTRODUCCIÓN 4

2 PROTOCOLOS DE SEGURIDAD 6

2.1 TRANSPORT LAYER SECURITY 6
2.1.1 INTRODUCCIÓN 6
2.1.2 ESTADOS DE SESIÓN Y DE CONEXIÓN 9
2.1.3 IMPLEMENTACIÓN DE TLS 10
2.1.3.1 El protocolo handshake 10
2.1.3.2 El protocolo change cipher spec 12
2.1.3.3 El protocolo Alert protocol 12
2.1.3.4 El protocolo TLS record protocol 13
2.1.4 VERSIONES DE TLS 15
2.1.4.1 TLS 1.0 15
2.1.4.2 TLS 1.1 16
2.1.4.3 TLS 1.2 16
2.1.4.4 TLS 1.3 17
2.1.5 ATAQUES CONOCIDOS CONTRA TLS/SSL 19
2.2 DATAGRAM TRANSPORT LAYER SECURITY 20
2.2.1 CAPA DE REGISTRO (DTLS RECORD PROTOCOL) 20
2.2.2 HANDSHAKE PROTOCOL 21
2.2.3 VERSIONES DE DTLS 22
2.3 IPSEC 23
2.3.1 INTRODUCCIÓN 23
2.3.2 DESCRIPCIÓN DEL PROTOCOLO IPSEC 24
2.3.2.1 Asociación de seguridad 25
2.3.2.2 El protocolo AH 26
2.3.2.3 El protocolo ESP 29
2.3.2.4 Modos de transporte y túnel 34
2.3.3 SERVICIOS DE SEGURIDAD OFRECIDOS POR IPSEC 35

3 CORTAFUEGOS 36

3.1 INTRODUCCIÓN 36
3.2 FUNCIONES DE UN CORTAFUEGO 36
3.3 TIPOS DE CORTAFUEGOS 37
3.3.1 FILTRADO DE PAQUETES 37
3.3.2 PROXY – GATEWAYS DE APLICACIONES 38
3.3.3 INSPECCIÓN DE PAQUETES (DETECCIÓN DE INTRUSOS) 39

4 REDES PRIVADAS VIRTUALES 39

4.1 TUNNELING 39
4.1.1 CONCEPTO 39
4.1.2 TÚNELES EN CAPAS DE ENLACE Y RED 40
4.2 INFRAESTRUCTURA VPN 40

4.2.1 INTRODUCCIÓN 40
4.2.2 ELEMENTOS DE UNA CONEXIÓN VPN 41
4.2.3 FUNCIONAMIENTO GENERAL DE UNA VPN 42

5 MEDIDAS ESPECÍFICAS PARA LAS COMUNICACIONES MÓVILES 42

5.1 SEGURIDAD EN REDES 5G 42
5.2 MEDIDAS CONCRETAS DE SEGURIDAD 48

6 AMENAZAS LÓGICAS 50

6.1 DENEGACIÓN DE SERVICIO (INTERRUPCIÓN) 50
6.2 INTERCEPCIÓN (ESCUCHA O MONITORIZACIÓN) 52
6.3 SUPLANTACIÓN (IMPOSTURA O FABRICACIÓN) 54
6.4 MODIFICACIÓN (MANIPULACIÓN) 56

1 Introducción

Desde el mismo momento en que nos conectamos a una red no dejamos de enviar y recibir información. Esta información circula por la red de forma que el destinatario pueda recibirla y enviar una respuesta en caso necesario. Tenemos, pues, que cuando dos o más ordenadores están conectados a una misma red, existe la posibilidad de que estos ordenadores puedan acceder a esta información, e incluso a los otros ordenadores conectados. Esta característica, deseable en la mayoría de ocasiones, puede volverse en nuestra contra fácilmente.

Desde el mismo momento en que interesa que una información no sea pública necesitamos controlar el acceso a toda información para decidir si debe ser pública o debemos protegerla mediante sistemas de seguridad. La necesidad de seguridad siempre viene precedida de una amenaza (justificada o no).

"Se entiende por amenaza una condición del entorno del sistema de información (persona, máquina, suceso o idea) que, dada una oportunidad, podría dar lugar a que se produjese una violación de la seguridad (confidencialidad, integridad, disponibilidad o uso legítimo)."

En una red dónde millones de ordenadores intercambian innumerable cantidad de información mediante el envío y recepción de datagrama según el conjunto de protocolos TCP/IP, podemos distinguir tres cualidades básicas deseables en toda comunicación:

- Secreta. No sólo respecto al contenido de la información enviada/recibida, sino también al origen y destino de la información.
- Auténtica. Los datos no han sido modificados, provienen del origen legítimo (no hay suplantación de un usuario por otro y no pueden ser repudiados) y son ciertos en el momento de su recepción.
- Accesible. Tanto el emisor como el receptor han de poder intercambiar información cuando sea necesario.

Las amenazas a su vez pueden ser clasificadas principalmente en cuatro grupos distintos:

- Interrupción. El acceso a un recurso/comunicación se ve interrumpido ya sea físicamente (destrucción de la red...) o lógicamente (se modifica la localización, los derechos de acceso...).
- Intercepción. Alguien no autorizado consigue tener acceso al recurso/comunicación (pinchar la línea de red, sniffing...).
- Modificación. Obtención no sólo de acceso no autorizado al recurso/comunicación, sino también de la capacidad de modificarlo (modificación de los datos enviados/recibidos entre dos ordenadores...).
- Fabricación. Además de conseguir acceso al recurso/comunicación, se tiene la posibilidad de insertar información falsa.

Podemos clasificar los posibles ataques en pasivos y activos.

En los **ataques de tipo pasivo** el atacante no altera la comunicación, tan sólo tiene acceso a ella. De esta forma puede saber qué información circula por el canal, a qué horas, la frecuencia y entre qué personas. Este tipo de ataque es muy difícil de detectar ya que no aparece ningún signo que nos pueda advertir de que estamos siendo atacados.

Por el contrario, en los **ataques activos** el atacante modifica el flujo de datos transmitidos o incluso crea uno falso, permitiendo incluso la suplantación de un usuario legítimo. Esto tipo de ataques es mucho más grave, ya que además de conseguir interceptar la comunicación, puede modificar su contenido falseándola, lo que implica que en caso de usar algún sistema de seguridad, éste ha sido violado y se ha descubierto su clave de acceso o una de ellas (si es que hay) y el método utilizado para cifrar y descifrar la información.

Desde los inicios de Internet y hasta finales de los años 90, casi toda la información que circulaba por Internet no utilizaba ningún tipo de cifrado, atravesando todas las máquinas que encontraba hasta en destinatario tal y como había sido enviada

Posteriormente, su expansión hacia el público en general hizo que el número de usuarios creciera exponencialmente. La proliferación de ataques realizados por desaprensivos, que aprovechaban las debilidades de unos protocolos diseñados sin ninguna seguridad, empezó a inundar los medios informativos. Esto obligó a los diseñadores de protocolos a añadir algunos parches y extensiones de emergencia a unos protocolos que no habían sido diseñados para ello.

De forma paralela el comercio electrónico (e-commerce) se empezaba a desarrollar, y diferentes soluciones fueron adoptadas por las empresas implicadas. Todas estas soluciones siempre se englobaron en las capas superiores de los protocolos (TCP).

Ello obliga a pensar en el concepto de seguridad: Se entiende por seguridad (o sistema de seguridad) de los sistemas de información al conjunto de funciones, servicios y mecanismos que permitan garantizar las siguientes premisas:

- Autenticación. Se define como la característica de dar y reconocer la autenticidad de ciertas informaciones del Dominio y/o la identidad de los actores y/o la autorización por parte de los autorizadores, así como la verificación de esas cuestiones.
- Confidencialidad. Se define como la "condición que asegura que la información no pueda estar disponible o ser descubierta por o para personas, entidades o procesos no autorizados".
- Integridad. Se define como la "condición de seguridad que garantiza que la información es modificada, incluyendo su creación y destrucción, sólo por el personal autorizado".
- Disponibilidad. Se define como el "grado en el que un dato está en el lugar, momento y forma en que es requerido por el usuario autorizado. Situación que se produce cuando se puede acceder a un Sistema de Información en un periodo de tiempo considerado aceptable". Se asocia a menudo a la fiabilidad técnica (tasa de fallos) de los componentes del sistema de información.

Además de satisfacer los anteriores requisitos, los sistemas de seguridad pueden proporcionar una serie de servicios entre los que destacan:

- Servicios de no-repudiación. Impiden que un usuario pueda negar haber recibido un documento electrónico.
- Reclamación de origen. Constituye la contrapartida del servicio anterior, en el sentido de que permite probar quién es el creador de un determinado documento.
- Reclamación de propiedad. Este servicio permite probar que un determinado documento electrónico es de propiedad de un usuario particular. Se usa en transacciones mercantiles, donde la posesión de un documento concede determinados derechos a su poseedor.
- Accesibilidad. En su sentido más general, éste es el servicio cuyo objetivo es el de permitir que ciertos datos sólo sean accesibles por personas autorizadas.
- Intercambio equitativo de valores. Este servicio es importante en todas aquellas operaciones comerciales o mercantiles en las que la cesión de un documento por una de las partes implicadas supone la recepción de otro documento a cambio, como en el intercambio de contratos y en la realización de pagos. El servicio garantiza que la transacción se realiza en los términos acordados o que, en caso contrario, la parte en desacuerdo recuperará los documentos que haya entregado.
- Certificación de fechas. En las comunicaciones electrónicas este servicio es el equivalente al certificado de fecha y/u hora a la que se ha realizado o entregado un determinado documento.

El sistema de seguridad requerido por un SI o una organización variará dependiendo de una serie de factores, entre los que pueden destacarse los siguientes:

- Localización geográfica de los usuarios.
- Topología de la red de comunicaciones.
- Instalaciones o salas donde residen los equipos físicos.
- Equipo físico que soporta el SI.
- Configuración del equipo lógico básico.
- Tipo y estructura de las bases de datos.
- Forma de almacenamiento de los datos.
- Número y complejidad de los procesos a realizar.

2 Protocolos de seguridad

2.1 Transport Layer Security

2.1.1 Introducción

Como vimos anteriormente, toda transacción segura por la red debe contemplar los aspectos de seguridad tales como autenticidad, integridad y confidencialidad.

Son varios los sistemas y tecnologías que se han desarrollado para intentar implementar estos aspectos en las transacciones electrónicas. De entre ellos, SSL ha sido el más

conocido y usado durante muchos años. SSL es un protocolo considerado inseguro actualmente, y no válido para el intercambio seguro de información.

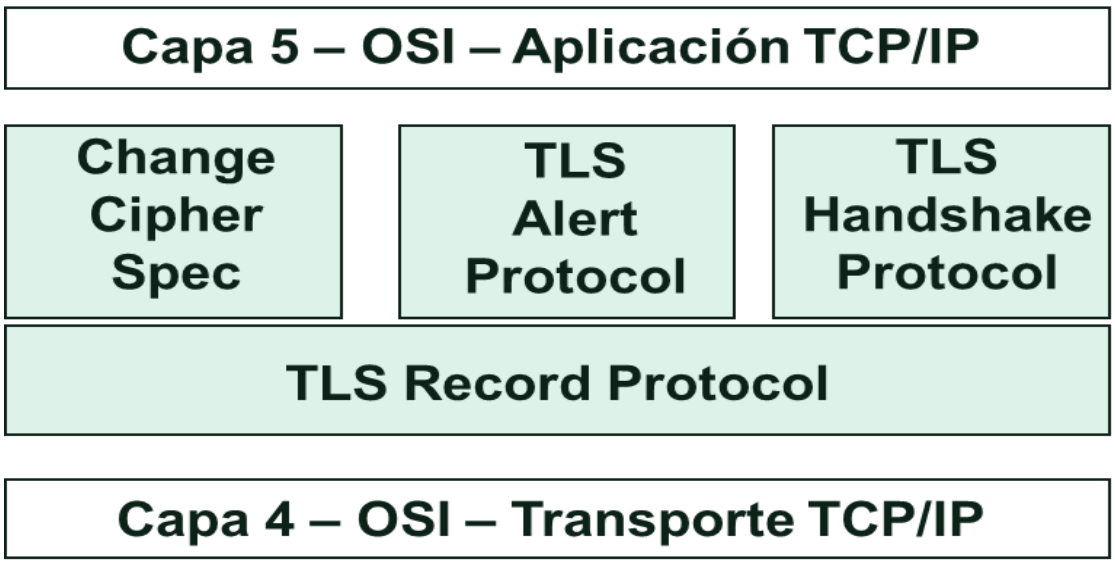
El protocolo más utilizado actualmente es TLS (Transport Layer Security). TLS permite ofrecer confidencialidad e integridad en las transacciones por Internet. Además, el protocolo ofrece autenticación del servidor, y permite a la aplicación solicitar la autenticación del cliente.

TLS es un sistema de protocolos de carácter general que está basado en la aplicación conjunta de Criptografía Simétrica, Criptografía Asimétrica (de llave pública) y certificados digitales para conseguir un canal o medio seguro de comunicación a través de Internet. De los sistemas criptográficos simétricos, motor principal de la encriptación de datos transferidos en la comunicación, se aprovecha la rapidez de operación, mientras que los sistemas asimétricos se usan para el intercambio seguro de las claves simétricas, consiguiendo con ello resolver el problema de la confidencialidad en la transmisión de datos.

TLS implementa un protocolo de negociación para establecer una comunicación segura a nivel de socket (nombre de máquina más puerto), de forma transparente al usuario y a las aplicaciones que lo usan.

El objetivo principal del protocolo TLS es proporcionar privacidad y fiabilidad entre dos aplicaciones que se comunican. El protocolo está compuesto por dos capas:

- En el nivel más bajo, soportado sobre algún protocolo de transporte fiable (por ejemplo, TCP) está la capa de TLS record protocol. El TLS record protocol se utiliza para la encapsulación de los datos procedentes de diversos protocolos de nivel superior.
- En un nivel por encima, el TLS handshake protocol, permite al cliente y al servidor autenticarse mutuamente y negociar un algoritmo de cifrado y claves criptográficas antes de que el protocolo de aplicación transmita o reciba su primer byte de datos.



Una de las ventajas de TLS es que es independiente del protocolo de aplicación. Un protocolo de capa superior puede usar el protocolo TLS de forma transparente. El protocolo TLS proporciona una conexión de seguridad que tiene tres propiedades básicas:

- La conexión es privada (confidencialidad). El cifrado se usa después de la fase inicial handshake para definir una clave secreta. La criptografía simétrica se utiliza para el cifrado de datos.
- La identidad del par puede ser autenticada utilizando criptografía de clave pública o asimétrica. Esta autenticación puede ser opcional, pero normalmente se requiere para uno de los dos pares.
- La conexión es fiable (integridad). El transporte de mensajes incluye un chequeo de integridad de mensaje utilizando un código de autenticación de mensaje (HMAC) con clave. Se emplean funciones de seguridad hash para el cálculo del código HMAC.

La identidad del servidor web seguro (y a veces también del usuario cliente) se consigue mediante el certificado digital correspondiente, del que se comprueba su validez antes de iniciar el intercambio de datos sensibles (autenticación).

La integridad de los datos intercambiados se asegura mediante funciones hash y la comprobación de los resúmenes de todos los datos enviados y recibidos.

Por último, la confidencialidad se asegura mediante el uso de funciones de criptografía simétrica.

Desde el punto de vista de su implementación en los modelos de referencia OSI y TCP/IP, TLS se introduce como una especie de nivel o capa adicional, situada entre la capa de Aplicación y la capa de Transporte.

Existen varios protocolos de aplicación que utilizan TLS para ofrecer seguridad a la información intercambiada. La asignación de puerto por defecto para los protocolos que utilizan TLS es la siguiente:

Identificador de protocolo	Puerto TCP	Descripción
HTTPS	443	HTTP sobre TLS
SMTPS	465	SMTP sobre TLS
NNTPS	563	NNTP sobre TLS
LDAPS	636	LDAP sobre TLS
TELNETS	992	TELNET sobre TLS
IMAPS	993	IMAP sobre TLS
IRCS	994	IRC sobre TLS
POP3S	995	POP3 sobre TLS
FTPS-data	989	FTP-Datos sobre TLS
FTPS-control	990	FTP-Control sobre TLS

2.1.2 Estados de sesión y de conexión

Durante el proceso de comunicación segura en TLS existen dos estados fundamentales, el **estado de sesión** y el **estado de conexión**.

El estado de sesión se identifica con una asociación entre el cliente y el servidor. Estas sesiones se crean a través del protocolo handshake. Una sesión define un entorno criptográfico que puede ser compartido durante distintas conexiones. Las sesiones son creadas para evitar negociar en cada conexión todos los parámetros de seguridad, ya que este es un proceso costoso.

Un estado de sesión incluye los siguientes elementos:

- **Identificador de sesión**. Un número arbitrario elegido por el servidor para identificar la sesión.
- **Certificado**. El certificado X509v3 del otro.
- **Método de compresión**. Algoritmo de compresión.
- **Algoritmo de cifrado**. Especifica el algoritmo simétrico de cifrado para confidencialidad y la función Hash de resumen para integridad. También se definen atributos de Hash o cifrado.
- **Clave maestra**. Un número de 48 bytes secreto entre el servidor y cliente.
- **Flag de nuevas conexiones**. Indica si desde esta sesión se pueden iniciar nuevas conexiones.

El estado de conexión se identifica con un servicio de transporte, asociado a una determinada sesión. Es una relación uno a uno. Las conexiones son transitorias. Un estado de conexión incluye los siguientes elementos:

- **Clave de cifrado simétrico del cliente**. Clave secreta utilizada por el cliente para cifrar sus mensajes mediante el algoritmo simétrico negociado.
- **Clave de cifrado simétrico del servidor**. Clave secreta utilizada por el servidor para cifrar sus mensajes mediante el algoritmo simétrico negociado.
- **Clave para cálculo del MAC del cliente**. Clave secreta utilizada por el cliente para calcular los MAC de sus mensajes.
- **Clave para cálculo del MAC del servidor**. Clave secreta utilizada utilizado por el servidor para calcular los MAC de sus mensajes.
- **Vectores iniciales de cliente (IV)**. Si se utiliza cifrado con modo CBC (Cipher Bloack Chainning) se necesita un vector inicial para que el cliente pueda cifrar.
- **Vectores iniciales de servidor (IV)**. Si se utiliza cifrado con modo CBC (Cipher Bloack Chainning) se necesita un vector inicial para que el servidor pueda cifrar.

Vamos a ver a continuación de forma detallada el proceso completo de trabajo de TLS.

2.1.3 Implementación de TLS

2.1.3.1 El protocolo handshake

Los parámetros criptográficos del estado de sesión se producen en el TLS handshake protocol, que opera en la capa por encima del TLS record protocol. Los mensajes de este protocolo se deben enviar en un determinado orden. Un error o un fallo en el protocolo de conexión u otro error de protocolo desencadena la terminación de la conexión, opcionalmente precedida por un mensaje de alerta.

Cuando un cliente TLS y un servidor comienzan a comunicarse, acuerdan una versión de protocolo, seleccionan algoritmos criptográficos, opcionalmente se autentican mutuamente, y utilizan técnicas de cifrado con clave pública para generar o crear secretos compartidos. Una vez que el handshake se ha completo, los pares usan las claves establecidas para proteger el tráfico procedente de la capa de aplicación.

Estos procesos se ejecutan en el protocolo handshake, que se puede resumir, de forma general, de la siguiente manera:

Cuando un cliente se conecta por primera vez a un servidor, se requiere que envíe un mensaje “client hello” como su primer mensaje. Este mensaje incluye una secuencia aleatoria, que se utiliza más adelante en el protocolo. Además, el cliente envía una lista en donde se indica la combinación de algoritmos criptográficos soportada por el cliente, en orden de preferencia (lo que se conoce como la suite criptográfica).

El servidor seleccionará una suite de cifrado o, si no se le presenta ninguna elección aceptable, devolverá una alerta de fallo en el handshake y cerrará la conexión.

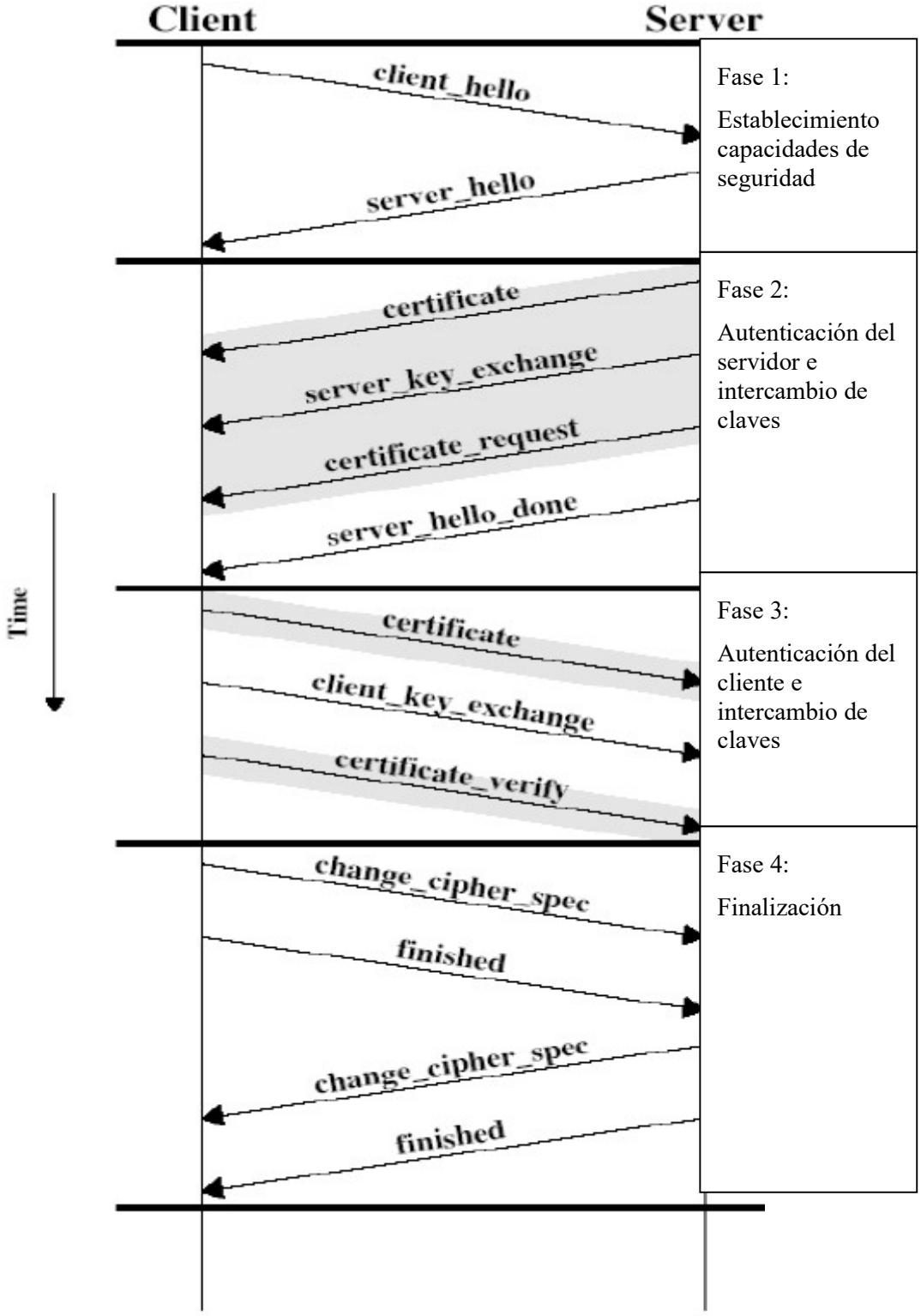
El mensaje de client hello incluye una lista de los algoritmos de compresión soportados por el cliente, en el orden de preferencia del cliente. Si el servidor no soporta ninguno de los especificados, la sesión se cerrará. Por último, el cliente indicará la versión del protocolo TLS que el cliente quiere utilizar en esta sesión. Una vez enviado el mensaje, el cliente espera la respuesta del servidor.

El servidor procesa el mensaje “client hello” y responde con un mensaje de error o con un mensaje “server hello”. El servidor indicará, en primer lugar, la versión del protocolo TLS que van a utilizar. El servidor genera, además, un número aleatorio diferente e independiente del generado por el cliente. Además, se fija el Id de la sesión. Por último, el servidor fija la suite criptográfica que van a utilizar cliente y servidor en la comunicación, y selecciona el método de compresión.

Si el servidor se va a autenticar (que suele ser el caso) el servidor envía su certificado inmediatamente después del mensaje “server hello”. El tipo de certificado tiene que ser apropiado para el algoritmo de intercambio de claves seleccionado en la suite criptográfica, y es generalmente un certificado del tipo x.509 v3. Este mismo tipo de mensaje es el que utiliza el cliente si se le requiere el envío de un certificado. Si, por el contrario, el servidor no dispone de un certificado x.509 v3, en ese caso envía un mensaje “server key Exchange” en el que incluye la clave pública. Una vez que el servidor ha finalizado el envío de información, manda un mensaje “server hello done” de finalización de esta fase.

Una vez que el cliente ha recibido la clave pública del servidor, el cliente genera el secreto pre-maestro, que es una clave de 48 bytes, a partir de los dos números aleatorios

generados anteriormente. Este secreto pre-maestro el cliente lo cifra con la clave pública del servidor, y se lo envía mediante un mensaje client_key_exchange. Con este secreto pre-maestro, cliente y servidor generan de forma independiente la master key o secreto maestro, clave de la que derivan las claves criptográficas utilizadas en el estado de conexión.



Una vez finalizado el intercambio de mensajes, se envía un mensaje Change Cipher Spec y un último mensaje de finalización para verificar que el intercambio de claves y el proceso de autenticación se realizaron correctamente. Este mensaje final es el primero que se envía con los algoritmos y claves recién negociados. Los mensajes Change Cipher Spec y Finished son enviados tanto por el cliente como por el servidor.

A partir de la clave maestra, cliente y servidor generan las claves propias del estado de conexión para cifrar la información que se intercambian.

2.1.3.2 El protocolo change cipher spec

El protocolo change cipher spec existe para enviar señales de cambios o transiciones en las estrategias de cifrado. El protocolo consiste en un único mensaje, que se cifra y comprime bajo la actual suite criptográfica. El mensaje se compone de un único byte de valor 1.

El mensaje de change cipher spec se envía tanto por el cliente como por el servidor y sirve para notificar a la parte receptora que los registros posteriores serán protegidos por las claves y la suite criptográfica recién negociadas.

2.1.3.3 El protocolo Alert protocol

Cuando se produce un posible error o una posible violación de algún elemento, el protocolo alert protocol se encarga de enviar un mensaje. Los mensajes de alerta del protocolo transmiten la gravedad del mensaje y una descripción de la alerta. Si el mensaje de alerta indica que el nivel de error es un nivel fatal, se produce una terminación inmediata de la conexión. En este caso, otras conexiones correspondientes a la sesión podrían continuar, pero el identificador de la sesión debe ser invalidado, y se impide la creación de nuevas conexiones.

Al igual que el resto de los mensajes, los mensajes de alerta también van cifrados y se comprimen, utilizando las claves y algoritmos negociados en la fase de handshake.

Alertas de cierre

El cliente y el servidor deben compartir el conocimiento de que la conexión está terminando con el objetivo de evitar un ataque de truncamiento. Cualquiera de las partes podrá iniciar el intercambio de mensajes de cierre. Para ello, enviará una alerta de close_notify al destinatario, que indica que el remitente no enviará más mensajes es esta conexión. Los datos recibidos después de una alerta de cierre se ignoran.

Alertas de error

La gestión de errores en el protocolo TLS es muy sencilla. Cuando se detecta un error, la parte que lo detecta envía un mensaje a la otra parte. Después de la transmisión o la recepción de un mensaje de alerta fatal, ambas partes cierran inmediatamente la conexión. Se requiere que los servidores y clientes olviden cualquier identificador, clave o secreto compartido asociado con una conexión fallida. Se definen las siguientes alertas de error:

Unexpected_message: se recibió un mensaje inapropiado. Siempre es un error fatal.

Bad_record_mac: se recibió un MAC incorrecto. Siempre es un error fatal.

Decompression_failure: se recibió una entrada impropia para la función de descompresión. Siempre es un error fatal.

Handshake_failure: no se pueden negociar parámetros de seguridad. Siempre es un error fatal.

No_certificate: No se recibió un certificado apropiado.

Bad_certificate: el certificado estaba corrupto.

Unsupported_certificate: el certificado es de un tipo que no se soporta.

Certificate_revoked: el certificado está revocado.

Certificate_expired: el certificado ha expirado.

Certificate_unknown: alguna cuestión relacionada con el procesamiento del certificado no es válida.

Illegal_parameter: un campo en el handshake está fuera de rango o es inconsistente con otros campos. Siempre es un error fatal.

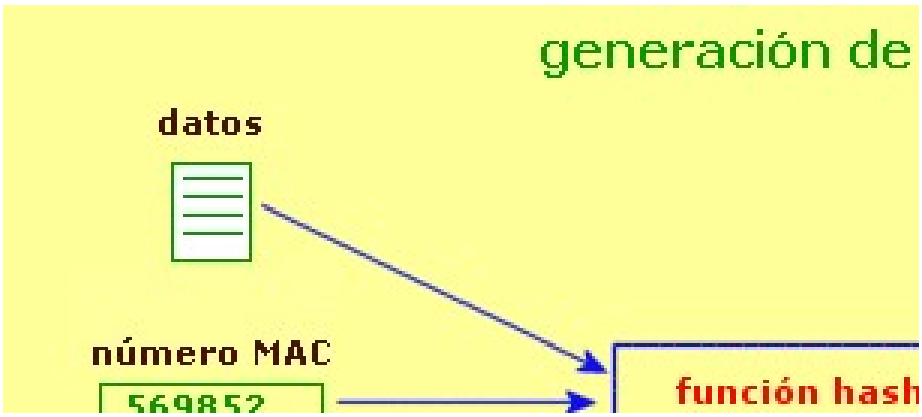
2.1.3.4 El protocolo TLS record protocol

La capa de registro TLS recibe los datos no interpretados desde las capas superiores en bloques no vacíos de tamaño arbitrario.

Una vez recibidos los datos, se realizan o se pueden realizar las siguientes funciones:

- **Fragmentación**: El protocolo TLS record protocol fragmenta los datos en bloques de información de tamaño inferior a 2^{14} bytes. Los límites del mensaje del cliente no se conservan en esta fragmentación.
- **Compresión** / descompresión: Todos los registros obtenidos después de la fragmentación se comprimen utilizando el algoritmo de compresión definido en el estado de sesión actual. Siempre hay un algoritmo de compresión definido.
- **Cifrado y función de integridad**: A continuación, se realiza el cifrado y la generación del código de integridad/autenticación (MAC) utilizando la suite criptográfica que se haya definido en la fase de handshake.

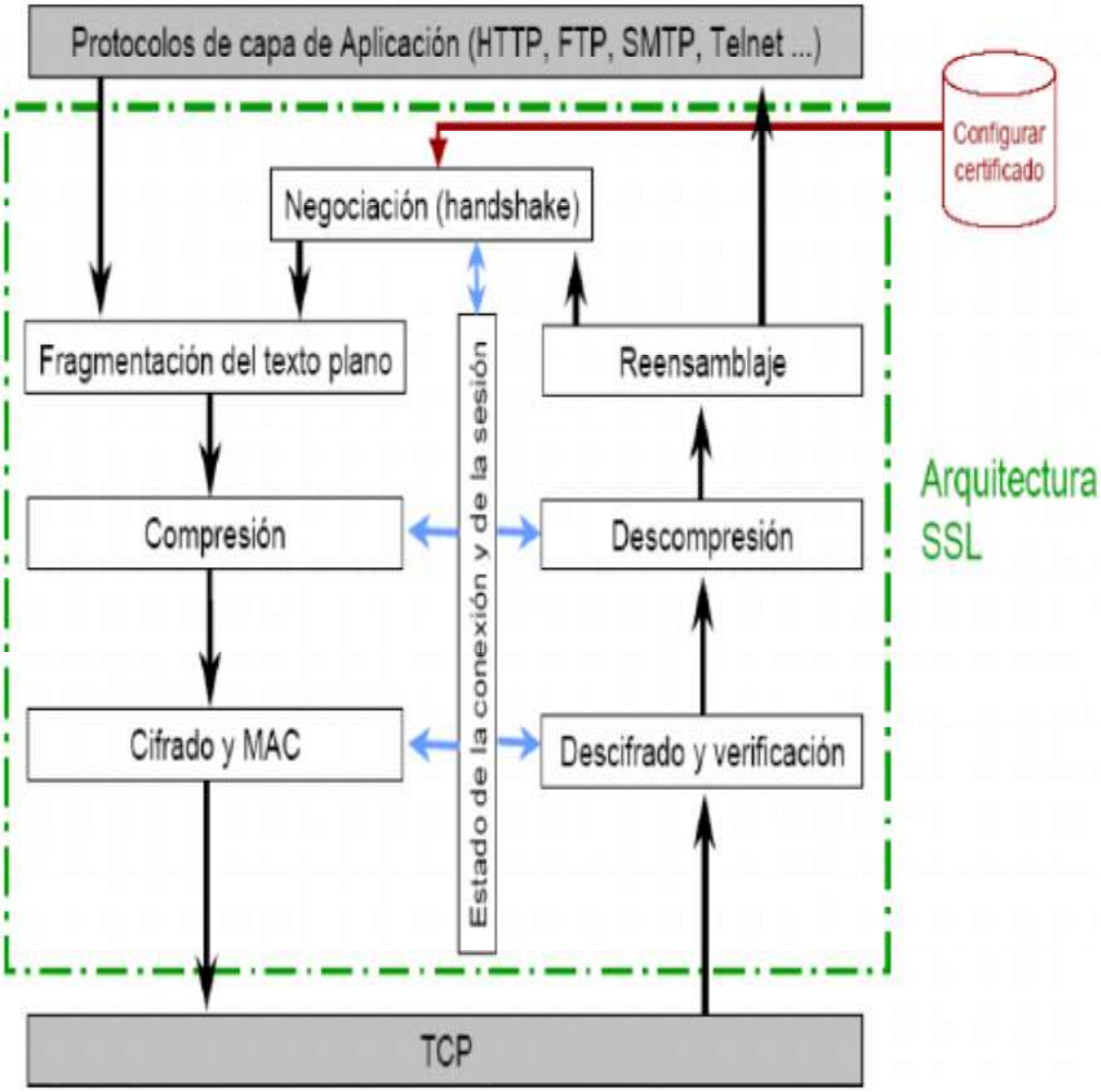
  El código MAC se obtiene concatenando un número de secuencia y el número secreto MAC establecidos en el estado de conexión, junto con los datos recibidos. El resultado de esta concatenación se añade al mensaje. Con esta base, la autenticación se comprueba mediante el número secreto, compartido por el cliente y el servidor, y mediante el número de secuencia, que viaja siempre cifrado. La integridad se comprueba mediante la función hash negociada.



La confidencialidad se asegura cifrando los bloques y sus resúmenes mediante el algoritmo simétrico y la clave correspondiente negociadas en la fase Handshake. Existen dos tipos posibles de encriptación:

- Cifrado en bloque: se cifran los datos en bloques de 64 bits. Si el mensaje no es múltiplo de 64 bits se le añaden los bits de relleno necesarios para obtener un número entero de bloques completos, indicándose la adición en el formato del mensaje. Este método de cifrado se conoce con el nombre de Cipher Block Chainning, CBC, y precisa un vector inicial, que habrá sido negociado previamente en la fase Handshake. Como algoritmos de cifrado se puede usar RC2.
- Cifrado Stream o de flujo, en el que se cifran los datos realizando una operación lógica OR-Exclusiva entre los bytes y un generador pseudoaleatorio, usado por ejemplo en el algoritmo RC4.

Una vez que la fase de handshake se ha completado, las dos partes han compartido los algoritmos y las claves necesarias para cifrar y generar los códigos de autenticación de mensaje que se añaden a los contenidos. Las funciones de descifrado y regeneración del código de autenticación invierten el proceso. Las transmisiones también incluyen un número de secuencia, de tal manera que los mensajes adicionales, alterados, o los que faltan, también se detectan.



2.1.4 Versiones de TLS

2.1.4.1 TLS 1.0

TLS 1.0 fue definido en el RFC 2246 en enero de 1999 y es una actualización de SSL versión 3.0. Como dice el RFC, "las diferencias entre este protocolo y SSL 3.0 no son dramáticas, pero son significativas en impedir la interoperabilidad entre TLS 1.0 y SSL 3.0". TLS 1.0 incluye una forma en la cual la implementación puede conectarse en SSL 3.0, debilitando la seguridad.

2.1.4.2 TLS 1.1

TLS 1.1 fue definido en el RFC 4346 en abril de 2006. Es una actualización de TLS 1.0. Las diferencias más significativas incluyen:

- Agrega protección contra ataques de CBC.
    - El vector de inicialización (IV) implícito fue reemplazado por un IV explícito.
    - Cambio en el manejo de los errores de relleno.
- Soporte para el registro de parámetros de IANA.

2.1.4.3 TLS 1.2

TLS 1.2 fue definido en el RFC 5246 en agosto del 2008. Se basa en una especificación posterior de TLS 1.1. Las mayores diferencias son:

- la combinación MD5-SHA-1 en la función pseudoaleatoria (PRF) fue reemplazada por SHA-256, con la opción de usar PRFs especificados en la cipher-suite.
- la combinación MD5-SHA-1 en el mensaje terminado fue reemplazada por SHA-256, sin la opción de usar algoritmos de hash específicos para la cipher-suite. Sin embargo, el tamaño del hash en el mensaje terminado es truncado a 96 bits.
- la combinación MD5-SHA-1 en el elemento digitalmente firmado fue reemplazada por un hash simple negociado durante el handshake, que por defecto es SHA-1.
- Mejoras en la habilidad de clientes y servidores para especificar que algoritmos de hash y de firma van a aceptar.
- Expansión del soporte de cifras de cifrado autenticadas, usadas mayormente para modo Galois/Counter (GCM) y modo CCM del cifrado con Advanced Encryption Standard (o estándar de cifrado avanzado) (AES).
- Se agregaron definición de Extensiones de TLS y de Ciphersuites de AES.

TLS 1.2 fue después redefinido en el RFC 6176 de marzo de 2011 redactando su retrocompatibilidad con SSL y TLS para que dichas sesiones jamás negocien el uso de SSL versión 2.0.

Respecto al intercambio de claves, previo a que el cliente y el servidor puedan empezar a intercambiar información protegida por TLS, deben intercambiar o acordar una clave maestra para cifrar los datos. Los métodos utilizados para acordar dicha clave maestra pueden ser RSA, Diffie-Hellman, Diffie-Hellman efímero, Diffie-Hellman de Curva elíptica, Diffie-Hellman de Curva elíptica efímero, Diffie-Hellman anónimo (no autentica, por lo que es vulnerable a ataques de suplantación de identidad) y PSK (pre-

shared keys, claves simétricas pre-compartidas). Solamente Diffie-Hellman efímero y Diffie-Hellman de curva elíptica efímero garantizan secreto perfecto hacia delante.

En cuanto a los algoritmos de cifrado simétrico, se pueden emplear distintos tipos, como pueden ser AES, Camellia, SEED, ChaCha20 junto con Poly1305, IDEA, 3DES, DES, RC2 y RC4, considerándose actualmente como seguros AES, Camellia, SEED, ChaCha20 junto con Poly1305, e IDEA en determinadas ocasiones.

Para la implementación de las funciones HMAC, se pueden utilizar MD5, SHA-1 (no recomendados), SHA-256 y SHA-384.

TLS 1.2 especifica 37 suites de cifrado permitidas.

2.1.4.4 TLS 1.3

TLS 1.3 es la nueva versión del protocolo TLS, introducido con el objetivo de mejorar la seguridad en el intercambio de los datos y la rapidez en la conexión. Se encuentra definida en la RFC 8446. Las principales diferencias con respecto a las versiones anteriores son las siguientes:

Intercambio de claves:

TLS admite tres modos básicos de intercambio de claves:

- (EC) DHE (Diffie-Hellman efímero sobre campos finitos o de curvas elípticas)
- Intercambio de claves mediante PSK (Pre-shared Keys): Una vez que se ha completado un handshake, el servidor puede enviar al cliente una PSK que corresponde a una clave única derivada de la inicial clave maestra. El cliente puede utilizar esta PSK en futuros handshakes para autenticarse. En este caso, la conexión no garantiza el secreto perfecto hacia adelante.
- Intercambio de claves mediante PSK con (EC) DHE: Al combinar una PSK con DHE, este modo garantiza el secreto perfecto hacia adelante a la vez que limita el número de costosas operaciones de clave pública que el servidor necesita realizar.

Estos modos de intercambio de claves proveen secreto perfecto hacia delante (excepto PSK), basado en crear una clave secreta distinta para cada comunicación. Esta clave secreta es posteriormente eliminada, haciendo imposible recuperar las claves en un futuro y descifrar todas las comunicaciones.

Handshake con conexión 1-RTT (Round Trip Time):

Las versiones previas a TLS 1.3 llevaban a cabo una negociación conocida como "2-RTT", que significa que se necesitaban dos viajes de ida y vuelta de datos entre cliente y servidor para negociar los términos mediante los cuales se llevaría a cabo la transferencia de datos. Esto supone emplear entre 0.25 y 0.50 segundos en ejecutar el protocolo Handshake.

Dado que no es posible reducir la latencia de estos mensajes, con TLS 1.3 se reduce el número de viajes necesarios para establecer la conexión. En TLS 1.3 se reduce a tan solo un viaje de ida y vuelta (1-RTT) el proceso de negociación.

Conexiones 0-RTT:

TLS 1.3 proporciona ventajas para conexiones iniciadas o reanudadas. Como alrededor del 40% de las conexiones https son reanudadas, para ganar velocidad en el establecimiento de la comunicación, se utiliza el protocolo 0-RTT, una tecnología que permite que las solicitudes https sean tan rápidas como las solicitudes http.

Esta tecnología permite reanudar una comunicación con los parámetros ya negociados previamente en la conexión anterior, evitando volver a tener que iniciar el proceso de handshake desde el inicio.

0-RTT permite que, cuando cliente y servidor ya comparten una PSK porque ya habían iniciado una comunicación anteriormente, pueden volver a reanudar la comunicación pudiendo enviar datos en el primer viaje del proceso de handshake (early_data).

En este caso, no se garantiza el secreto perfecto hacia delante.

Además, las solicitudes enviadas como parte de una reanudación 0-RTT son vulnerables a ataques de repetición. Si un atacante logra obtener acceso a la conexión cifrada entre cliente y servidor y consigue los datos de la primera solicitud, puede hacer una copia de los mismos y enviar la solicitud al servidor suplantando la identidad del cliente. El servidor verá solicitudes repetidas pero no tiene forma de saber el origen de procedencia de los datos, por lo que el atacante realizará el ataque con éxito. No obstante, existen mecanismos para evitar estos ataques de repetición.

Suites de cifrado:

Las suites de cifrado permitidas en TLS 1.3 son aquellas que soportan cifrado autenticado con datos asociados (AEAD).

El cifrado autenticado con datos asociados es una forma de cifrado que proporciona simultáneamente confidencialidad, integridad y garantías de autenticidad de los datos.

Las cinco suites de cifrado permitidas en TLS 1.3, siguiendo el formato algoritmo AEAD seguido de la función Hash, son las siguientes:

- TLS_AES_128_GCM_SHA256
- TLS_AES_256_GCM_SHA384
- TLS_CHACHA20_POLY1305_SHA256
- TLS_AES_128_CCM_SHA256
- TLS_AES_128_CCM_8_SHA256

Las funciones hash se utilizan con HKDF (HMAC Key Derivation Function).

Otras características:

Se elimina el soporte de hora GMT a favor de UTC.

La nueva versión es invulnerable a los ataques que intentan forzar el uso de una versión inferior de TLS (a fin de poder aprovecharse de las debilidades de ella), acabando definitivamente con este vector de ataque.

Se mantiene la estructura de los mensajes Hello para permitir compatibilidad con versiones anteriores.

2.1.5 Ataques conocidos contra TLS/SSL

Ataque de renegociación: Existe una vulnerabilidad en el procedimiento de renegociación que puede producir ataques de inyección de texto plano contra SSL 3.0 y todas las versiones actuales de TLS. El atacante puede secuestrar una conexión https para empalmar sus propias peticiones en el inicio de la conversación del cliente con el servidor web, pero no puede descifrar la comunicación entre cliente y servidor.

Ataques de reversión de versiones: En algunas ocasiones, se han producido ataques enfocados a modificar el conjunto de algoritmos de cifrado que envía el cliente al servidor, intentando un algoritmo con cifrado simétrico más débil, con el objeto de atacar esos cifrados y acceder a los datos.

Ataque BEAST (Browser Exploit Against SSL/TLS): Se desarrolló un applet Java para violar restricciones de políticas de mismo origen, a través de una vulnerabilidad de CBC en TLS 1.0.

Ataque CRIME (Compression Ratio Info-leak Made Easy): Ataque que permite a un atacante recuperar el contenido de una cookie de autenticación cuando se utiliza compresión de datos, y le permite secuestrar una sesión en una sesión web autenticada.

Ataque BREACH (Reconocimiento de Browser y exfiltración mediante Compresión adaptable de hipertexto): Ataque basado en el ataque anterior. El ataque permite al atacante obtener tokens para login, direcciones de correo o datos descifrados en conexiones HTTP sobre TLS que utilicen compresión de datos.

Ataques de relleno: Las versiones iniciales de TLS eran vulnerables frente al ataque de relleno de datos. En 2013 se publicó una nueva variante, llamada Ataque Trece con suerte. Existe una solución contra este ataque publicada en la RFC 7366.

Ataque Poodle (Padding Oracle on Downgraded Legacy Encryption): Se trata de un ataque sobre el modo de operación CBC con SSL 3.0. De media, los atacantes sólo necesitan hacer 256 peticiones SSL 3.0 para revelar un byte de mensaje cifrado. En 2014 la vulnerabilidad se ha extendido a TLS, para aquellas implementaciones que no fuerzan apropiadamente los requerimientos de rellenos de bytes.

Ataques contra RC4: Existen ataques documentados que permiten recuperar partes del texto en claro con un gran número de cifrados TLS.

Ataque de truncamiento: un ataque de truncamiento TLS bloquea las peticiones de desconexión de la cuenta de la víctima para que, sin saberlo, el usuario permanezca conectado a un servicio web. El servidor no recibe la solicitud de cierre de sesión, y el atacante puede tomar el control de la cuenta que había iniciado el usuario.

Fallo Heartbleed: Heartbleed es un fallo de seguridad de software de la biblioteca de código abierto OpenSSL, en sus versiones 1.0.1 a 1.0.1f, que permite a un atacante leer la memoria de un servidor o de un cliente, permitiéndole acceder a las claves privadas de SSL de un servidor.

2.2 Datagram Transport Layer Security

Es un protocolo de capa de transporte (definido en el RFC4347 de abril de 2006) que provee seguridad a protocolos que usan datagramas. La información es cargada en registros y estos componen la capa de registro o Record layer.

DTLS reutiliza casi todos los elementos del protocolo TLS, con pequeñas pero importantes modificaciones para que funcione correctamente con el transporte de datagramas. TLS depende de un subconjunto de funciones TCP: entrega de paquetes confiable y en orden y detección de repetición. Todas estas características están ausentes en el transporte de datagramas, por lo que es necesario introducir una serie de modificaciones. A continuación, se describe el protocolo DTLS y cómo se enfrenta a la ausencia de estas características.

2.2.1 Capa de registro (DTLS Record Protocol)

Al igual que en TLS, todos los datos en DTLS se llevan en registros. En ambos protocolos, los registros sólo se pueden procesar cuando el registro completo está disponible. Para evitar el tratamiento de la fragmentación, se necesita que los registros en DTLS se ajusten dentro de un único datagrama.

En la capa de registro aparecen dos nuevos campos introducidos por DTLS que están ausentes de los registros TLS: Epoch y Sequence number. Estos campos son necesarios para que el servidor pueda determinar el cifrado que se ha realizado al enviar los datos.

Epoch: Los números epoch se utilizan en los puntos finales para determinar qué tipo de cifrado se ha utilizado para proteger la carga útil del registro. Se requieren números epoch para resolver la ambigüedad que surge cuando se produce la pérdida de datos durante una renegociación de sesión.

Para ilustrar este punto, se puede considerar un cliente que transmite los registros de datos 7, 8 y 9, seguido del mensaje ChangeCipherSpec en el registro 10. Eventualmente, el servidor recibe los registros 7 y 9 (se pierden 8 y 10). Desde el punto de vista del servidor, el registro 8 podría haber sido el mensaje ChangeCipherSpec, en cuyo caso se asume que el registro 9 está asociado (incorrectamente) con el estado de cifrado pendiente. Dado que los números epoch se incrementan al enviar un ChangeCipherSpec message, el servidor puede utilizar el número epoch para resolver la ambigüedad. En este caso, los registros 7 y 9 tienen el mismo epoch, lo que implica que el registro 8 debe haber sido un registro de datos.

Número de secuencia: TLS emplea números de secuencia de registros implícitos (RSN) para protección de repetición. Los números de secuencia de registros desempeñan un papel similar en DTLS, pero deben especificarse explícitamente ya que los registros pueden perderse o ser entregados fuera de servicio. Al igual que con TLS,

los números de secuencia de registros se incrementan en uno para cada registro y se restablecen a cero siempre que el estado de cifrado se desplaza debido a una renegociación de sesión.

Hay que tener en cuenta que los números de secuencia en DTLS son de 48 bits (en TLS son 64 bits) y por lo tanto el espacio total ocupado por epoch y el número de secuencia es el mismo que el número de secuencia en TLS (este número de 64 bits es el que se utiliza para el cálculo del MAC).

Carga útil en DTLS: DTLS requiere que un registro entre completamente dentro de un único datagrama. Esto significa que los registros DTLS a menudo serán más pequeños que los registros TLS. El paquete más grande que se puede transmitir entre dos hosts, la unidad de transmisión máxima de ruta (PMTU), es típicamente menor que el tamaño máximo de un registro TLS.

2.2.2 Handshake protocol

El primer mensaje de ClientHello contiene la versión del protocolo que soporta, un número aleatorio, la identificación de la sesión, un campo vacío para el almacenamiento de una cookie que será suministrado por el servidor, sugerencias sobre el cifrado que pueden usar y el método de compresión que soporta.

A continuación, el servidor envía un mensaje de HelloVerifyRequest escogiendo la versión del protocolo y una cookie, un número que debe ser generado de tal manera que no haya consumo de memoria en almacenamiento, como por ejemplo usar la dirección IP del cliente y generar un hash de ésta con una llave global.

Como respuesta al mensaje anterior, el cliente verifica la cookie recibida y reenvía el mensaje de inicio de sesión con la cookie verificada.

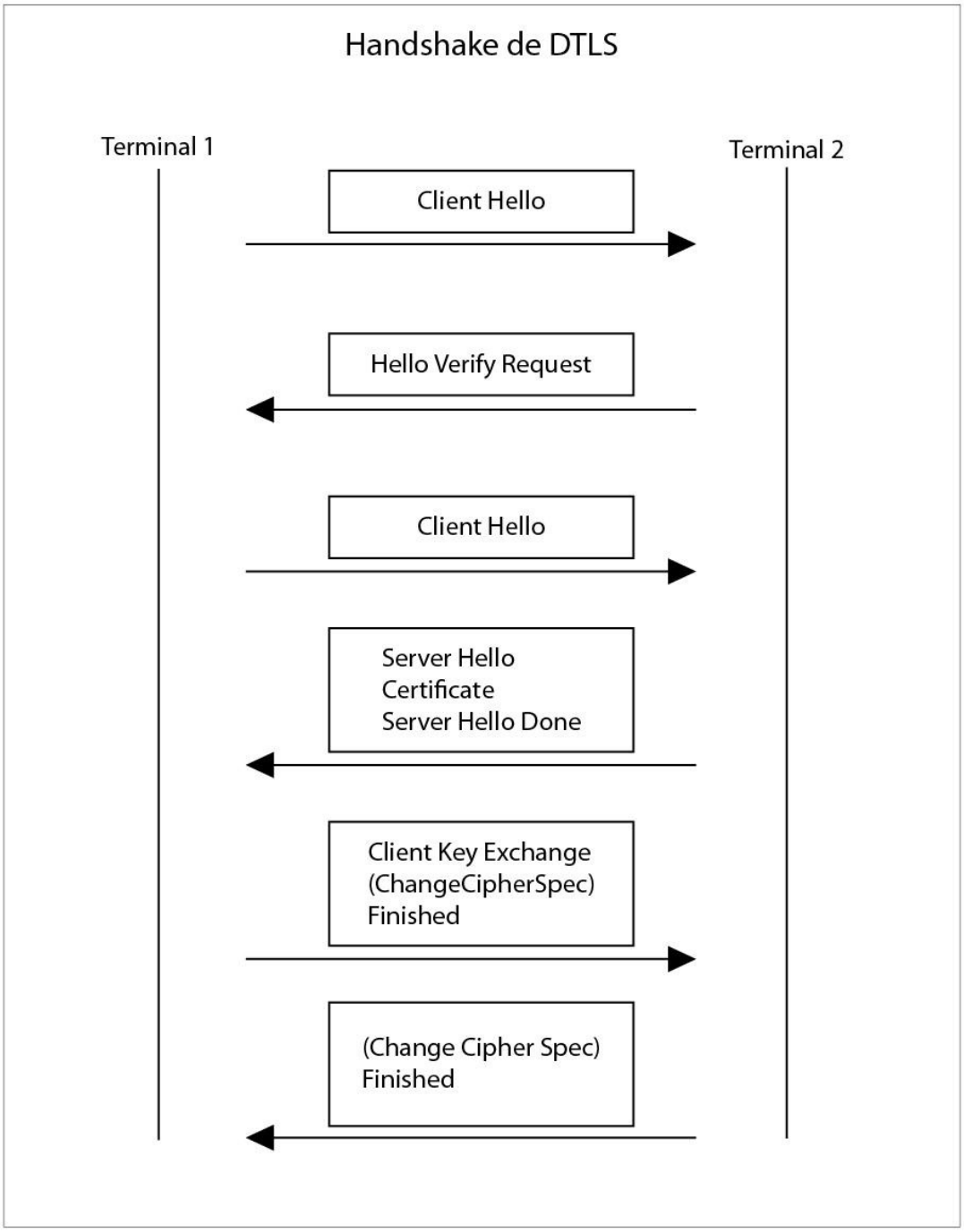
El servidor certifica al cliente y envía tres mensajes al cliente, ServerHello, Certificate y ServerHelloDone:

- El primer mensaje da respuesta a los requerimientos de versión del protocolo DTLS, el tipo de llave a usar, y el método de compresión.
- El segundo, que depende del protocolo de cifrado escogido, se puede utilizar para verificar la autenticidad del servidor.
- Finalmente, en el tercero se indica que terminó la etapa de negociación del handshake.

Posteriormente, el cliente envía un mensaje de ClientKeyExchange para generar la clave de la sesión (pre-master key), cifrado con la clave pública del servidor, y un mensaje con su certificado. También envía un mensaje Change Cipher Spec indicando que la información que de allí en adelante se envíe, va a estar cifrada y autenticada, y envía un mensaje de Finished que contiene el hash de todos los mensajes enviados previamente.

Por su parte el servidor también envía sus mensajes de Change Cipher Spec y de Finished para así finalizar el handshake y comenzar la transmisión.

Ambas partes verifican el hash de los mensajes, y si alguno falla, se descarta el handshake y se reinicia el proceso.



2.2.3 Versiones de DTLS

DTLS 1.0 está basado en TLS 1.1, y DTLS 1.2 está basado en TLS 1.2. No existe la versión DTLS 1.1, que se saltó para armonizar los números de versión con los de DTLS.

Existe el borrador de la versión DTLS 1.3, basado en la versión TLS 1.3. Esta nueva versión introduce las siguientes novedades:

- Nuevo patrón de hankshake, lo que lleva a un intercambio de mensajes más corto
- Soporte para cifrados solo de AEAD: las suites de cifrado son las mismas que para TLS 1.3.
- Negociación más flexible de cifrados
- Nuevo mecanismo de reanudación de sesión
- Autenticación de PSK redefinida
- Se elimina la compatibilidad con algoritmos criptográficos más antiguos y más débiles

2.3 IPSec

2.3.1 Introducción

IPSec es un estándar que proporciona servicios de seguridad a la capa IP y a todos los protocolos superiores basados en IP (TCP y UDP, entre otros). Se pretende disponer de un estándar que aborde las carencias en cuanto a seguridad del protocolo IP. Dichas carencias son muy graves y, tal como se ha constatado en los últimos años, afectan a la infraestructura misma de las redes IP.

Todas las soluciones anteriores se basaban en soluciones propietarias que dificultaban la comunicación entre los distintos entornos empresariales, al ser necesario que éstos dispusiesen de una misma plataforma.

La falta de interoperabilidad ha sido el principal freno para el establecimiento de comunicaciones seguras, dado que no se ve factible la migración a una determinada plataforma en función de una colaboración empresarial puntual.

Entre las ventajas de IPSec destacan que está apoyado en estándares del IETF y que proporciona un nivel de seguridad común y homogéneo para todas las aplicaciones, además de ser independiente de la tecnología física empleada. IPSec se integra en la versión actual de IP (IP versión 4) y, lo que es todavía más importante, se incluye por defecto en IPv6.

Puesto que la seguridad es un requisito indispensable para el desarrollo de las redes IP, IPSec está recibiendo un apoyo considerable: todos los equipos de comunicaciones lo incorporan, así como las últimas versiones de los sistemas operativos más comunes. Al mismo tiempo, ya existen muchas experiencias que demuestran la interoperabilidad entre fabricantes, lo cual constituye una garantía para los usuarios.

Otra característica destacable de IPSec es su carácter de estándar abierto. Se complementa perfectamente con la tecnología PKI y, aunque establece ciertos algoritmos comunes, por razones de interoperabilidad, permite integrar algoritmos criptográficos más robustos que pueden ser diseñados en un futuro.

Entre los beneficios que aporta IPSec, cabe señalar que:

- Posibilita nuevas aplicaciones como el acceso seguro y transparente de un nodo IP remoto.
- Facilita el comercio electrónico de negocio a negocio, al proporcionar una infraestructura segura sobre la que realizar transacciones usando cualquier aplicación. Las extranets son un ejemplo.
- Permite construir una red corporativa segura sobre redes públicas, eliminando la gestión y el coste de líneas dedicadas.
- Ofrece al teletrabajador el mismo nivel de confidencialidad que dispondría en la red local de su empresa, no siendo necesaria la limitación de acceso a la información sensible por problemas de privacidad en tránsito.

Es importante señalar que cuando citamos la palabra "seguro" no nos referimos únicamente a la confidencialidad de la comunicación, también nos estamos refiriendo a la integridad de los datos, que para muchas compañías y entornos de negocio puede ser un requisito mucho más crítico que la confidencialidad. Esta integridad es proporcionada por IPSec como servicio añadido al cifrado de datos o como servicio independiente.

Algunos documentos que recogen IPsec son:

- RFC 4301: Arquitectura de seguridad
- RFC 4302: AH
- RFC 4303: ESP
- RFC 7296: IKE
- RFC 8221: Requisitos de implementación de algoritmos criptográficos para AH y ESP

2.3.2 Descripción del protocolo IPSec

IPSec es, en realidad, un conjunto de estándares para integrar en IP funciones de seguridad basadas en criptografía.

IPsec está diseñado para proporcionar seguridad interoperable, de alta calidad, basada en criptografía tanto para IPv4 como para IPv6.

El conjunto de servicios de seguridad ofrecidos incluye: control de acceso, integridad sin conexión, autenticación del origen de los datos, protección antireplay y confidencialidad del flujo de tráfico (cifrado).

Estos servicios se implementan en la capa IP, y ofrecen protección para este nivel y/o los niveles superiores. Para ello, combina tecnologías de clave pública (RSA), algoritmos de cifrado (3DES, IDEA, Blowfish, AES, CHACHA20), algoritmos de hash (MD5, SHA1, SHA256) y certificados digitales X509v3. Los servicios se proporcionan en la capa IP, y pueden ser utilizados por cualquier protocolo de capa superior, por ejemplo, TCP, UDP, ICMP, BGP, etc.

IPsec se puede utilizar para proteger una o más "trayectorias" entre un par de hosts, o entre un par de security gateway, o entre un security gateway y un host. El término

security gateway se utiliza para referirse a un sistema intermedio que implementa los protocolos IPsec. Por ejemplo, un router o un firewall implementando IPsec es un security gateway.

El protocolo IPSec ha sido diseñado de forma modular, de modo que se pueda seleccionar el conjunto de algoritmos deseados sin afectar a otras partes de la implementación. Han sido definidos, sin embargo, ciertos algoritmos estándar que deberán soportar todas las implementaciones para asegurar la interoperabilidad en el mundo global de Internet. Dichos algoritmos de referencia son DES y 3DES, para cifrado, así como MD5 y SHA-1, como funciones de hash. Además, es perfectamente posible usar otros algoritmos que se consideren más seguros o más adecuados para un entorno específico: por ejemplo, como algoritmo de cifrado de clave simétrica IDEA, Blowfish o el más reciente AES.

Dentro de IPSec se distinguen los siguientes componentes:

- Dos protocolos de seguridad: IP Authentication Header (AH) e IP Encapsulating Security Payload (ESP) que proporcionan mecanismos de seguridad para proteger tráfico IP.
- Un protocolo de gestión de claves Internet Key Exchange (IKEv2) que permite a dos nodos negociar las claves y todos los parámetros necesarios para establecer una conexión AH o ESP (una asociación de seguridad).

El conjunto de protocolos IPsec empleados en cualquier conexión, y la forma en que se emplean, serán determinados por la seguridad, y los requerimientos del sistema del usuario, aplicaciones y/o sitios u organizaciones.

Estos protocolos pueden aplicarse solos o en conjunto con otros para proporcionar un conjunto de servicios de seguridad en IPv4 e IPv6. Cada protocolo soporta dos modos de uso: modo transporte y modo túnel. En modo transporte los protocolos proporcionan protección sobre todo a los protocolos de capa superiores; en modo túnel, los protocolos son aplicados a paquetes (a los que se hizo un túnel a través de IP).

2.3.2.1 Asociación de seguridad

Una Asociación de Seguridad (SA) es una "conexión" unidireccional que ofrece servicios de seguridad al tráfico transportado por este. Los servicios de seguridad ofrecidos en una SA son usados por AH o ESP, pero no por ambos.

Si ambos servicios de seguridad (AH y ESP) se aplican a un flujo de tráfico, se deben crear dos (o más) SAs para generar la protección de flujo de tráfico. Para asegurar la comunicación bidireccional entre dos hosts, o entre dos security gateway, se requieren dos Asociaciones de Seguridad para AH (uno en cada sentido) y otras dos Asociaciones de Seguridad para ESP (uno en cada sentido).

IKE crea explícitamente pares SA cuando se realiza la gestión de claves.

Una SA es identificada unívocamente por un trío que consiste en: un Índice de Parámetros de Seguridad (SPI), una Dirección IP de Destino, y un identificador de protocolo de seguridad (AH o ESP).

Según lo observado arriba, se definen dos tipos de SAs: modo transporte y modo túnel. Una SA en modo trasporte es una SA entre dos hosts. En IPv4, una cabecera de

protocolo de seguridad en modo transporte aparece inmediatamente después de la cabecera IP y de algunas opciones, y antes que cualquier protocolo de capas superior (por ejemplo, TCP o UDP). En IPv6 las cabeceras del protocolo de seguridad se situarán después de la cabecera IP y de extensiones pero deben aparecer antes o después de la cabecera de opciones de dirección y antes de los protocolos de capas superiores. En el caso de ESP, una SA en modo transporte proporciona servicios de seguridad solamente para los protocolos de las capas superiores, no para la cabecera IP o cualquier cabecera de extensión precedente a la cabecera ESP. En el caso de AH la protección se extiende a las partes seleccionadas de la cabecera IP, a las partes seleccionadas de las cabeceras de extensión y a las opciones seleccionadas (contenidas en la cabecera de IPv4, la cabecera de extensión Salto-por-Salto de IPv6, o la cabecera de extensión de destino de IPv6).

Los datagramas IP trasmitidos por una SA individual permiten la protección de un protocolo de seguridad, AH o ESP, pero no ambos. En ocasiones una política de seguridad puede determinar una combinación de servicios para un flujo de tráfico específico que no se puede realizar por una única SA. En estos casos será necesario emplear múltiples SAs para implementar la política de seguridad requerida. El término "grupo de asociaciones de seguridad" o "grupo de SA" se aplica a una secuencia de SAs las cuales deben procesar el tráfico para satisfacer una política de seguridad. El orden de la secuencia se define en la política de seguridad.

Hay 2 bases de datos nominales en este modelo: la Base de Datos de Políticas de Seguridad (SPD) y la Base de Datos de Asociaciones de seguridad (SAD). SPD especifica las políticas que determinan el tratamiento de todo el tráfico IP entrante o saliente en un host. SAD contiene los parámetros que se asocian con cada SA (activa).

En cada implementación de IPsec hay una SAD, en la cual cada entrada define los parámetros asociados con una SA. Cada SA tiene una entrada en la SAD.

Para el procesamiento de entrada: Los siguientes campos del paquete se usan para buscar la SA en la SAD:

- Dirección IP de Destino: La dirección de destino IPv4 o IPv6.
- Protocolo IPsec: AH o ESP, usado como un índice para buscar la SA en esta base de datos. Especifica el protocolo IPsec aplicado al tráfico en esta SA.
- SPI: es un valor de 32 bits que se usa para diferenciar SAs diferentes que tienen el mismo destino (la misma dirección IP de destino) y que usan el mismo protocolo IPsec.

2.3.2.2 El protocolo AH

El protocolo AH es el procedimiento previsto dentro de IPSec para garantizar la integridad sin conexión y autenticación del origen de datos para datagramas IP.

En concreto, AH se puede utilizar para proporcionar los siguientes servicios:

- Autenticación del origen de los datos (la autenticación del origen de los datos se proporciona indirectamente como resultado de vincular la clave que se utiliza para verificar la integridad de la identidad del par IPsec)
- Integridad sin conexión (este servicio se presta directamente)

- Servicio de anti-replay

Este último servicio es opcional y puede seleccionarse una vez que se ha establecido la Asociación de Seguridad (SA).

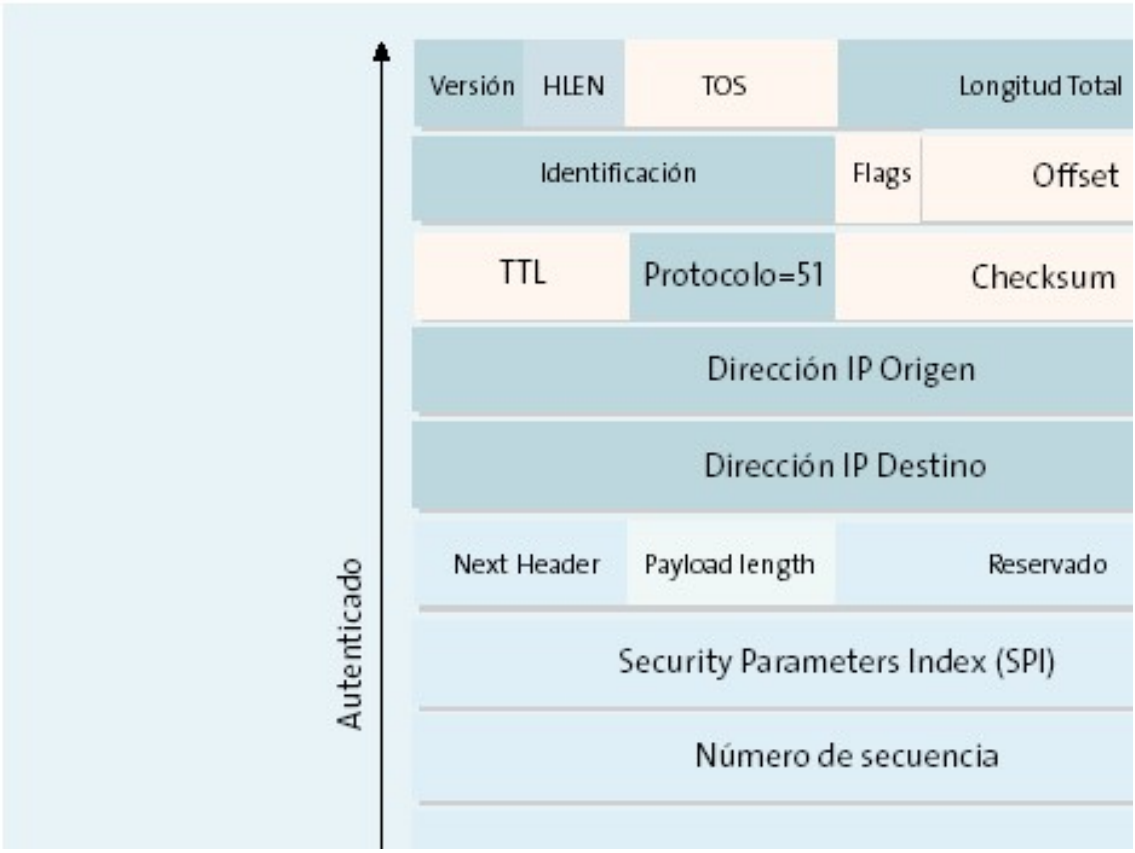
El protocolo AH no proporciona ninguna garantía de confidencialidad, es decir, los datos transmitidos pueden ser vistos por terceros.

AH proporciona autenticación a las partes de la cabecera IP que se les pueda brindar este servicio, así como también a los datos de los protocolos de las capas superiores. Sin embargo, algunos campos de la cabecera IP pueden cambiar durante el transporte, y el valor de estos campos, cuando el paquete llega al receptor, puede que no sea previsible para el emisor. Los valores de tales campos no pueden ser protegidos por AH. Así la protección proporcionada a la cabecera IP por AH se proporciona a fragmentos.

AH puede aplicarse solo, en combinación con el protocolo ESP, o de forma anidada. Las funciones hash recomendadas son SHA256 y SHA512

Tal como indica su nombre, AH es una cabecera de autenticación que se inserta entre la cabecera IP estándar (tanto IPv4 como IPv6) y los datos transportados, que pueden ser un mensaje TCP, UDP o ICMP, o incluso un datagrama IP completo.

AH es realmente un protocolo IP nuevo, y como tal el IANA le ha asignado el número decimal 51. Esto significa que el campo Protocolo de la cabecera IP contiene el valor 51, en lugar de los valores 6 ó 17 que se asocian a TCP y UDP respectivamente. Es dentro de la cabecera AH donde se indica la naturaleza de los datos de la capa superior. Es importante destacar que AH asegura la integridad y autenticidad de los datos transportados y de la cabecera IP, excepto los campos variables: TOS, TTL, flags, offset y checksum.



Todos los campos descritos a continuación son obligatorios, es decir, están siempre presentes en el formato de AH y se incluyen en el cálculo del Valor de Comprobación de Integridad (Integrity Check Value – ICV).

- La Cabecera Siguiente es un campo de 8 bits que identifica el tipo de carga siguiente después de la Cabecera de Autenticación. El valor de este campo se elige del conjunto de Números de Protocolo IP definidos en el más reciente RFC de "Números Asignados" por la Autoridad de Números de Asignación de Internet (IANA).
- La longitud de la Carga es un campo de 8 bits que especifica la longitud de AH en palabras de 32 bit (en unidades de 4 byte), menos "2".
- El campo Reservado es un campo de 16 bits que está reservado para uso futuro. DEBE ser fijado a "cero".
- El SPI es un valor arbitrario de 32 bits que, conjuntamente con la dirección de destino IP y el protocolo de seguridad (AH), identifican unívocamente a la Asociación de Seguridad para este datagrama.
- El campo Número de Secuencia es un campo de 32 bits sin signo que contiene un valor creciente y único del contador (de número de secuencia). Es obligatorio y debe estar siempre presente incluso si el receptor elige no habilitar el servicio de anti-replay para una SA específica. El contador del emisor y del receptor se inicializa a 0 cuando se establece una SA. (El primer paquete que se envíe bajo esa SA tendrá el Número de Secuencia 1).

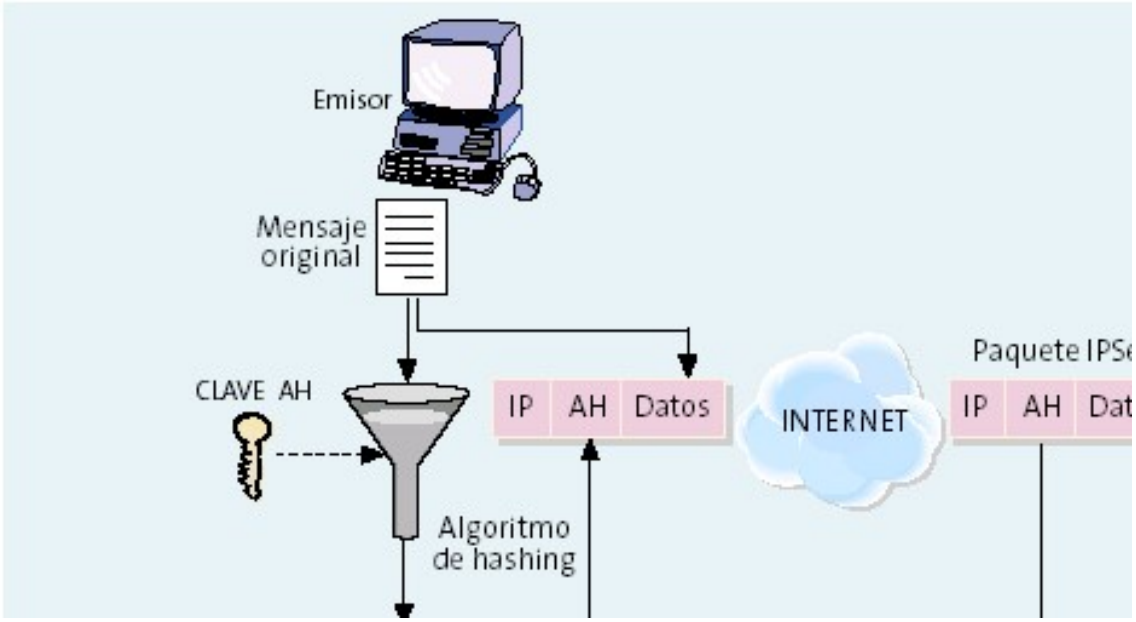
Para admitir implementaciones de Ipsec de alta velocidad, se deberían poder gestionar en las SA números de secuencia extendidos de 64 bits.

- El campo Datos de Autenticación es un campo de longitud variable y contiene el Valor de Comprobación de Integridad (ICV) para este paquete. Este campo debe contener un múltiplo entero de 32 bits de longitud.

El funcionamiento de AH se basa en un algoritmo HMAC, esto es, un código de autenticación de mensajes. Este algoritmo consiste en aplicar una función hash a la combinación de unos datos de entrada y una clave, siendo la salida una pequeña cadena de caracteres que denominamos extracto. Dicho extracto tiene la propiedad de que es como una huella personal asociada a los datos y a la persona que lo ha generado, puesto que es la única que conoce la clave.

En la figura se muestra el modo en que funciona el protocolo AH. El emisor calcula un extracto del mensaje original, el cual se copia en uno de los campos de la cabecera AH. El paquete así construido se envía a través de la red, repitiéndose en el extremo receptor el cálculo del extracto y comparándolo con el recibido en el paquete. Si son iguales, el receptor tiene la seguridad de que el paquete IP no ha sido modificado en tránsito y que procede efectivamente del origen esperado.

Si analizamos con detalle el protocolo AH, podemos concluir que su seguridad reside en que el cálculo del extracto (MAC) es imposible sin conocer la clave, y que dicha clave (en la Figura, clave AH) sólo la conocen el emisor y el receptor.



2.3.2.3 El protocolo ESP

El protocolo ESP está diseñado para proporcionar un conjunto de servicios de seguridad en IPv4 y en IPv6.

La cabecera ESP se inserta antes que la cabecera IP y después que la cabecera de protocolo de capa superior (en modo transporte) o después de una cabecera IP encapsulada (en modo túnel). Dado que ESP proporciona más funciones que AH, el formato de la cabecera es más complejo; este formato consta de una cabecera y una cola que rodean los datos transportados. Dichos datos pueden ser cualquier protocolo IP (por ejemplo, TCP, UDP o ICMP, o incluso un paquete IP completo). En la figura se muestra la estructura de un datagrama ESP, en la que se observa cómo el contenido o carga útil viaja cifrado.

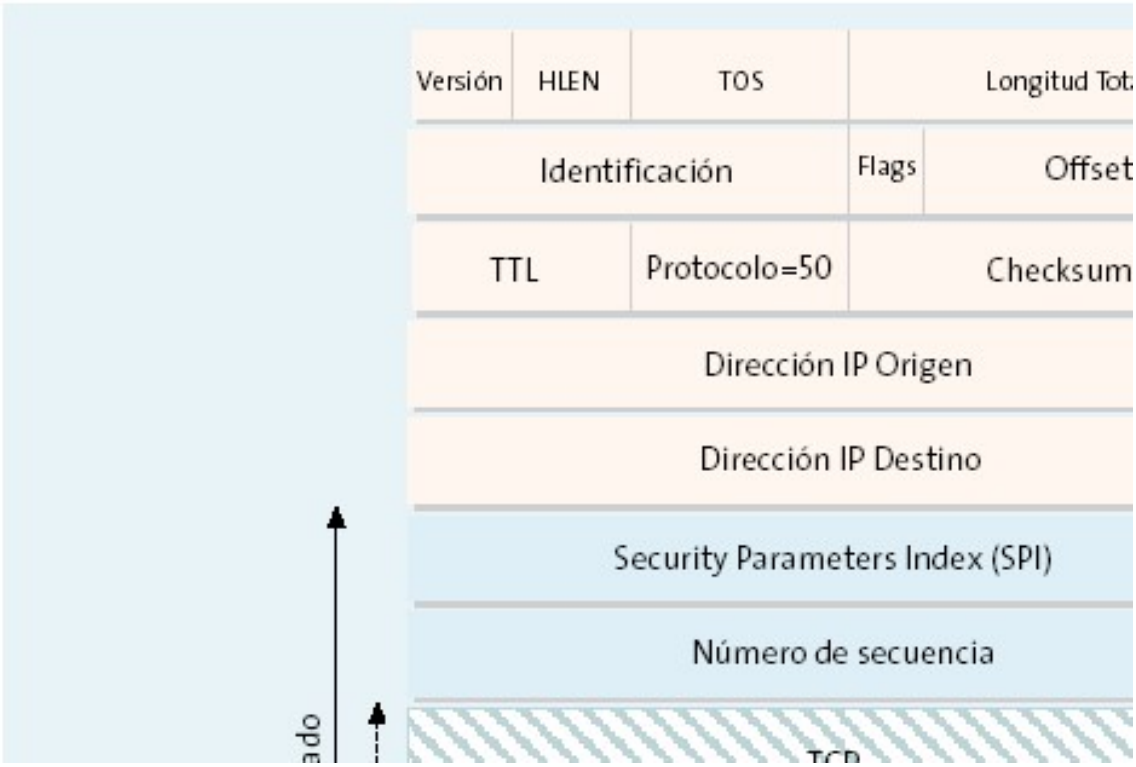
ESP se puede utilizar para proporcionar los siguientes servicios:

- Confidencialidad del flujo de tráfico
- Autenticación del origen de los datos (la autenticación del origen de los datos se proporciona indirectamente como resultado de vincular la clave que se utiliza para verificar la integridad de la identidad del par IPsec)
- Integridad sin conexión (este servicio se presta directamente)
- Servicio de anti-replay

El conjunto de servicios proporcionados depende de las opciones seleccionadas al momento del establecimiento de la Asociación de Seguridad (SA) y de dónde esté localizada la implementación.

ESP puede ser aplicado solo, o en combinación con el protocolo AH, o en forma anidada, por ejemplo, a través del uso del modo túnel.

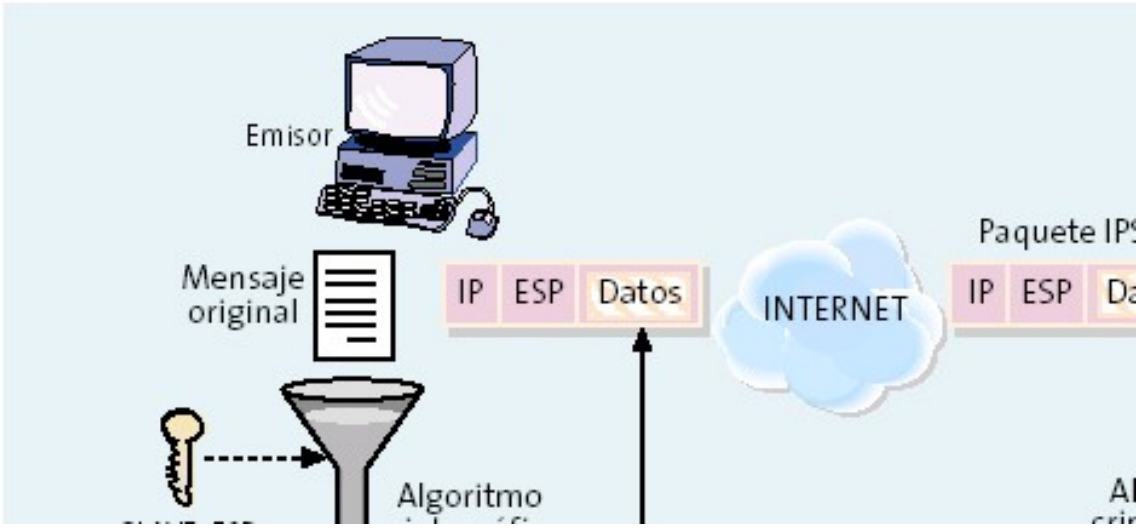
La cabecera del protocolo (IPv4, IPv6, o de Extensión) inmediatamente antes de la cabecera de ESP contendrá el valor 50 en su Protocolo (IPv4) o en el campo Siguiente Cabecera (de IPv6, o de Extensión).



El IANA ha asignado al protocolo ESP el número decimal 50. Esto implica que el campo Protocolo de la cabecera IP contendrá el valor 50, mientras que dentro del mensaje ESP se indica la naturaleza de los datos. Puesto que este campo, al igual que la carga útil, está cifrado, un hipotético atacante que intercepte el paquete no podrá saber si el contenido es TCP o UDP; esto es completamente normal ya que el objetivo que se persigue es, precisamente, ocultar la información.

La función de cifrado dentro del protocolo ESP es desempeñada por un algoritmo de cifrado de clave simétrica. Típicamente se usan algoritmos de cifrado bloque, de modo que la longitud de los datos a cifrar tiene que ser un múltiplo del tamaño de bloque (8 o 16 bytes, en la mayoría de los casos). Por esta razón existe un campo de relleno, tal como se observa en la figura, el cual tiene una función adicional: es posible añadir caracteres de relleno al campo de datos para ocultar así su longitud real y, por tanto, las características del tráfico. Un atacante suficientemente hábil podría deducir cierta información a partir del análisis de ciertos parámetros de las comunicaciones, aunque estén cifradas, tales como el retardo entre paquetes y su longitud. La función de relleno está pensada para dificultar este tipo de ataques.

En la figura se representa cómo el protocolo ESP permite enviar datos de forma confidencial. El emisor toma el mensaje original, lo cifra, utilizando una clave determinada, y lo incluye en un paquete IP, a continuación de la cabecera ESP. Durante el tránsito hasta su destino, si el paquete es interceptado por un tercero sólo obtendrá un conjunto de bits ininteligibles. En el destino, el receptor aplica de nuevo el algoritmo de cifrado con la misma clave, recuperando los datos originales.



Está claro que la seguridad de este protocolo reside en la robustez del algoritmo de cifrado, es decir, que un atacante no puede descifrar los datos sin conocer la clave, así como en que la clave ESP únicamente la conocen el emisor y el receptor. La distribución de claves de forma segura es, por consiguiente, un requisito esencial para el funcionamiento de ESP y también de AH, como hemos visto anteriormente.

Asimismo, es fundamental que el emisor y el receptor estén de acuerdo tanto en el algoritmo de cifrado o de hash y como en el resto de parámetros comunes que utilizan. Esta labor de puesta en contacto y negociación es realizada por un protocolo de control, denominado IKEv2.

El cifrado sin autenticación no es efectivo y no se recomienda utilizar. IPsec ofrece tres formas de proporcionar cifrado y autenticación:

- ESP con un cifrado autenticado con datos asociados (AEAD)
- ESP con un cifrado + autenticación no AEAD
- ESP con un cifrado no AEAD + AH con autenticación

El método más rápido y moderno es usar ESP con un modo combinado cifrado, como un cifrado AEAD, que maneja el cifrado / descifrado y autenticación en un solo paso. En este caso, el cifrado AEAD se establece como el algoritmo de cifrado y el algoritmo de autenticación se establece en none. Ejemplos de esto son ENCR_AES_GCM_16 y ENCR_CHACHA20_POLY1305.

Un enfoque más tradicional es usar ESP con un cifrado y un algoritmo de autenticación Este enfoque es más lento, ya que los datos tienen para ser procesado dos veces: una para cifrado / descifrado y otra para autenticación. Un ejemplo de esto es ENCR_AES_CBC combinado con AUTH_HMAC_SHA2_512_256.

El último método que se puede usar es ESP + AH. Este método no se recomienda. Es el método más lento y también ocupa más octetos debido al doble encabezado de ESP + AH. Con este método, ESP se utiliza solo para la confidencialidad sin un algoritmo de autenticación y el protocolo AH se utiliza para la autenticación. Un ejemplo de esto es ESP con ENCR_AES_CBC con AH con AUTH_HMAC_SHA2_512_256.

Los algoritmos recomendados son AES_CBC, AES_CCM_8 (AEAD), AES_GCM_16 (AEAD) y CHACHA20_POLY1305 (AEAD).

En cuanto a los campos, tenemos los siguientes:

- El SPI es un valor arbitrario de 32 bits que, conjuntamente con la dirección de destino IP y el protocolo de seguridad (ESP), identifican unívocamente a la Asociación de Seguridad para este datagrama.
- El número de Secuencia es un campo de 32 bits sin signo que contiene un valor creciente y único del contador (del número de secuencia). Es obligatorio y debe estar siempre presente. El contador del emisor y del receptor se inicializan a cero (0) cuando se establece una SA. El primer paquete que se envíe bajo esa SA tendrá el Número de Secuencia 1.

  Para admitir implementaciones de Ipsec de alta velocidad, se deberían poder gestionar en las SA números de secuencia extendidos de 64 bits.
- Los Datos de la Carga Útil es un campo de longitud variable que contiene los datos descritos por el campo Siguiente Cabecera. El campo Datos de la Carga Útil es obligatorio. Si el algoritmo usado para cifrar la carga útil requiere datos de sincronización criptográficos, por ejemplo, de un Vector de Inicialización (IV), estos datos SE PUEDEN llevar explícitamente en el campo Carga Útil.

El campo relleno (para el cifrado) se puede usar o requerir por varios motivos:

- Si se emplea un algoritmo de encriptación que requiere que el texto plano sea un múltiplo de un cierto número de bytes, por ejemplo, el tamaño de bloque de un bloque cifrado, el campo Relleno es usado para rellenar el texto plano (el cual consta de los Datos de la Carga Útil, y los campos Longitud del Relleno y Siguiente Cabecera, así como también del Relleno) para el tamaño requerido por el algoritmo.
- El relleno también puede ser requerido, independientemente de los requisitos del algoritmo de encriptación, para asegurarse de que el texto cifrado resultante termine en un límite de 4 bytes. Específicamente, los campos Longitud del Relleno y Siguiente Cabecera deben estar alineados correctamente dentro de una palabra de 4 bytes, para asegurarse de que el campo Datos de Autenticación (si está presente) esté alineado en un límite de 4 bytes.
- Más allá del relleno requerido para el algoritmo o por las razones de alineación citadas arriba, se puede utilizar para encubrir la longitud real de la carga, en respaldo de la confidencialidad (parcial) del flujo de tráfico.

El campo Longitud del Relleno indica el número de bytes de relleno inmediatamente precedentes a este campo. El rango de valores válidos es de 0 a 255 bytes, donde un valor de cero indica que no hay bytes de relleno presentes. El campo Longitud del Relleno es obligatorio.

La Siguiente Cabecera es un campo de 8 bits que identifica el tipo de datos contenidos en el campo Datos de la Carga Útil.

El campo Datos de Autenticación es de longitud variable y contiene el Valor de Comprobación de Integridad (ICV) calculado sobre el paquete ESP menos, los Datos de Autenticación.

2.3.2.4 Modos de transporte y túnel

Tanto ESP como AH proporcionan dos modos de uso:

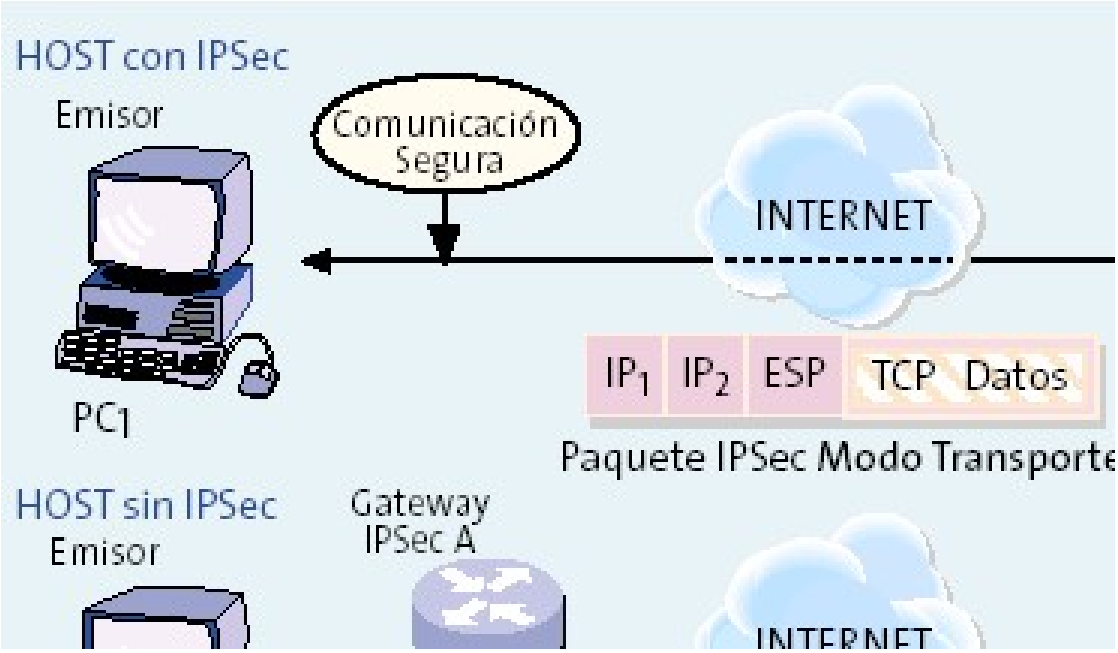
1. El modo transporte. En este modo el contenido transportado dentro del datagrama AH o ESP son datos de la capa de transporte (por ejemplo, datos TCP o UDP). Por tanto, la cabecera IPSec se inserta inmediatamente a continuación de la cabecera IP y antes de los datos de los niveles superiores que se desean proteger. El modo transporte tiene la ventaja de que asegura la comunicación extremo a extremo, pero requiere que ambos extremos entiendan el protocolo IPSec.
2. El modo túnel. En éste el contenido del datagrama AH o ESP es un datagrama IP completo, incluida la cabecera IP original. Así, se toma un datagrama IP al cual se añade inicialmente una cabecera AH o ESP, posteriormente se añade una nueva cabecera IP que es la que se utiliza para encaminar los paquetes a través de la red. El modo túnel se usa normalmente cuando el destino final de los datos no coincide con el dispositivo que realiza las funciones IPSec.

El modo túnel es empleado principalmente por los gateways IPSec, con objeto de identificar la red que protegen bajo una misma dirección IP y centralizar de este modo el procesado del tráfico IPSec en un equipo. El modo túnel también es útil, cuando se utiliza junto con ESP, para ocultar la identidad de los nodos que se están comunicando. Otra aplicación del modo túnel, tanto con ESP como con AH, es poder establecer Redes Privadas Virtuales (RPV) a través de redes públicas, es decir, interconectar de forma segura redes de área local, incluso en el caso de que éstas usen direccionamiento privado o no legal en Internet.

IPSec puede ser implementado bien en un host o bien en un equipo dedicado, tal como un router o un firewall, que cuando realiza estas funciones se denomina gateway IPSec. La figura muestra los dos modos de funcionamiento del protocolo IPSec, donde:

1. En la parte superior se representan dos hosts que entienden IPSec y que se comunican de forma segura. Esta comunicación se realiza en modo transporte, por tanto la información que se protege es únicamente el protocolo TCP o UDP, así como los datos de aplicación.

2. En la parte inferior se muestran dos redes que utilizan para conectarse dos gateways IPSec y, por tanto, emplean una implementación en modo túnel. Se puede ver que la comunicación se realiza a través de una red de datos pública, entre un PC situado en una red local con otro PC situado en una red local remota, de modo que entre los gateways IPSec se establece un túnel a través del cual viajan protegidas las comunicaciones entre ambas redes locales. Sin embargo ambos PCs envían y reciben el tráfico en claro, como si estuviesen situados en la misma red local. Este esquema tiene la ventaja de que los nodos situados en redes separadas pueden comunicarse de forma segura y transparente, concentrándose, al mismo tiempo, las funciones de seguridad en un único punto, facilitando así las labores de administración.



2.3.3 Servicios de seguridad ofrecidos por IPsec

En este apartado se analizan las características de los servicios de seguridad que ofrece IPSec. Dichos servicios son:

Integridad y autenticación del origen de los datos

El protocolo AH es el más adecuado si no se requiere cifrado. La opción de autenticación del protocolo ESP ofrece una funcionalidad similar, aunque esta protección, a diferencia de AH, no incluye la cabecera IP. Como se comentó anteriormente, esta opción es de gran importancia para aquellas aplicaciones en las cuales es importante garantizar la invariabilidad del contenido de los paquetes IP.

Confidencialidad

El servicio de confidencialidad se obtiene mediante la función de cifrado incluida en el protocolo ESP. En este caso es recomendable activar la opción de autenticación, ya que si no se garantiza la integridad de los datos el cifrado es inútil. Esto es debido a que aunque los datos no pudiesen ser interpretados por nadie en tránsito, éstos podrían ser alterados haciendo llegar al receptor del mensaje tráfico sin sentido que sería aceptado como tráfico válido.

Además de ofrecer el cifrado del tráfico, el protocolo ESP también tiene herramientas para ocultar el tipo de comunicación que se está realizando; para ello permite introducir caracteres de relleno en el contenido de los datos del paquete, de modo que se oculta la verdadera longitud del mismo. Ésta es una protección útil contra las técnicas de análisis de tráfico, que permiten a un atacante deducir información útil a partir del estudio de las características del tráfico cifrado. El análisis de tráfico es un riesgo que debe considerarse seriamente, recientemente se ha documentado la viabilidad para deducir información a partir del tráfico cifrado de una conexión SSH. Es previsible que este tipo de ataques se harán más habituales y sofisticados en el futuro, conforme se generalice el cifrado de las comunicaciones.

Detección de repeticiones

La autenticación protege contra la suplantación de la identidad IP, sin embargo un atacante todavía podría capturar paquetes válidos y reenviarlos al destino. Para evitar este ataque, tanto ESP como AH incorporan un procedimiento para detectar paquetes repetidos. Dicho procedimiento está basado en un número de secuencia incluido en la cabecera ESP o AH, el emisor incrementa dicho número por cada datagrama que envía y el receptor lo comprueba, de forma que los paquetes repetidos serán ignorados.

Esta secuencia no podrá ser modificada por el atacante, debido a que se encuentra protegida por medio de la opción de integridad para cualquiera de los dos protocolos (AH y ESP) y cualquier modificación en este número provocaría un error en la comprobación de la integridad del paquete.

Control de acceso: autenticación y autorización

Dado que el uso de ESP y AH requiere el conocimiento de claves, y dichas claves son distribuidas de modo seguro mediante una sesión IKE en la que ambos nodos se autentican mutuamente, existe la garantía de que sólo los equipos deseados participan en la comunicación. Es conveniente aclarar que una autenticación válida no implica un acceso total a los recursos, ya que IPSec proporciona también funciones de autorización.

No repudio

El servicio de no repudio es técnicamente posible en IPSec, si se usa IKE con autenticación mediante certificados digitales. En este caso, el procedimiento de autenticación se basa en la firma digital de un mensaje que contiene, entre otros datos, la identidad del participante. Dicha firma, gracias al vínculo entre la clave pública y la identidad que garantiza el certificado digital, es una prueba inequívoca de que se ha establecido una conexión IPSec con un equipo determinado, de modo que éste no podrá negarlo. En la práctica, sin embargo, esta prueba es más compleja, ya que requeriría almacenar los mensajes de negociación IKE y, además, no está definido un procedimiento para referenciar este evento a una fecha concreta.

3 Cortafuegos

3.1 Introducción

Un cortafuegos es una combinación de técnicas, políticas de seguridad y tecnologías (hardware y software) encaminadas a proporcionar seguridad en la red, controlando el tráfico que circula entre dos o más redes (y más concretamente, entre una red privada e Internet).

Un cortafuegos proporciona un **único punto de acceso** donde centralizar las medidas de seguridad y auditoría de la red.

Los cortafuegos deben combinarse con otras medidas de seguridad, para obtener una protección eficaz en nuestras redes.

3.2 Funciones de un cortafuego

Entre las funciones típicas de un cortafuego, se pueden citar las siguientes:

- ✓ Controlar, permitiendo o denegando, los accesos desde la red local hacia el exterior y os accesos desde el exterior hacia la red local (redes, subredes o nodos específicos y servicios)
- ✓ Control de acceso
- ✓ Registro de eventos y alertas: Almacenar total o parcialmente los paquetes que circulan a través de él para analizarlos en caso de problemas
- ✓ Filtrar los paquetes que circulan, de modo que sólo los servicios permitidos puedan pasar
- ✓ Traducción de direcciones (NAT)
- ✓ Monitorizar el tráfico, supervisando destino, origen y cantidad de información recibida y/o enviada
- ✓ Almacenar total o parcialmente los paquetes que circulan a través de él para analizarlos en caso de problemas
- ✓ Establecer un punto de cifrado de la información si se pretende comunicar dos redes locales a través de Internet. Establecimiento de VPNs
- ✓ Filtrado de contenidos
- ✓ Prevención de intrusiones

3.3 Tipos de cortafuegos

Existen distintos tipos de cortafuegos, dependiendo de las funcionalidades que ofrecen y de las capas OSI en las que actúan.

A continuación, se presenta una clasificación de los mismos:

3.3.1 Filtrado de paquetes

Se utilizan routers con filtros y reglas basadas en políticas de control de acceso. El router es el encargado de filtrar los paquetes, en base a cualquiera de los siguientes criterios:

- ✓ Protocolos utilizados
- ✓ Dirección IP de origen y de destino
- ✓ Puerto TCP – UDP de origen y de destino

Estos criterios permiten gran flexibilidad en el tratamiento del tráfico. Por **ejemplo**, se podría permitir navegar en la www (puerto 80 abierto), pero no acceder a la transferencia de ficheros vía ftp (puerto 21 cerrado).

Debido a su funcionamiento y estructura basada en el filtrado de direcciones y puertos, este tipo de cortafuegos trabaja en los niveles de transporte y de red del modelo OSI

Tienen la ventaja de ser económicos, tienen un alto nivel de desempeño y son transparentes para los usuarios conectados a la red. Sin embargo, presentan debilidades como:

- ✓ No protege las capas superiores a nivel OSI

- ✓ Las necesidades de las aplicaciones son difíciles de traducir como filtros de protocolos y puertos
- ✓ No soportan políticas de seguridad complejas, como autenticación de usuarios y control de accesos con horarios prefijados.
- ✓ Sus capacidades de auditoría suelen ser limitadas.
- ✓ Pueden constituir grandes cuellos de botella

3.3.2 Proxy – gateways de aplicaciones

Para evitar las debilidades asociadas al filtrado de paquetes, los desarrolladores crearon software de aplicación encargados de filtrar las conexiones. Estas aplicaciones son conocidas como **servidores proxy**, y la máquina donde se ejecuta recibe el nombre de **gateway de aplicación o bastión host**.

El proxy, instalado sobre el nodo bastión, actúa de intermediario entre el cliente y el servidor real de la aplicación, siendo transparente a ambas partes.

Cuando un usuario desea un servicio, lo hace a través del proxy. Este realiza el pedido al servidor real y devuelve los resultados al cliente. Su función es la de analizar el tráfico de red en busca de contenidos que violen la seguridad de la misma.

A continuación se detalla el funcionamiento del **servidor proxy de web**, el más común.

Cuando un equipo de la red desea acceder a una información o recurso, es realmente el proxy quien realiza la comunicación y a continuación traslada el resultado al equipo inicial. En unos casos esto se hace así porque no es posible la comunicación directa y en otros casos porque el proxy añade una funcionalidad adicional, como puede ser la de mantener los resultados obtenidos (p.ej.: una página web) en una cache que permita acelerar sucesivas consultas coincidentes. Con esta denominación general de proxy se agrupan diversas técnicas.

Reverse Proxy

Un reverse proxy es un servidor proxy instalado en el domicilio de uno o más servidores web. Todo el tráfico entrante de Internet y con el destino de uno de esos servidores web pasa a través del servidor proxy. Hay varias razones para instalar un "reverse proxy":

- **Seguridad**: el servidor proxy es una capa adicional de defensa y por lo tanto protege los servidores web.
- **Encriptación/Aceleración TLS**: cuando se crea un sitio web seguro, habitualmente la encriptación TLS no la hace el mismo servidor web, sino que es realizada por el "reverse proxy", el cual está equipado con un hardware de aceleración TLS.
- **Distribución de Carga**: el "reverse proxy" puede distribuir la carga entre varios servidores web. En ese caso, el "reverse proxy" puede necesitar reescribir las URL de cada página web (traducción de la URL externa a la URL interna correspondiente, según en qué servidor se encuentre la información solicitada)
- **Caché de contenido estático**: Un "reverse proxy" puede descargar los servidores web almacenando contenido estático como imágenes y otro contenido gráfico.

3.3.3 Inspección de paquetes (detección de intrusos)

Este tipo de cortafuegos se basa en el principio de que cada paquete que circula por la red es inspeccionado, así como también su procedencia y destino. Se aplican desde la capa de red hasta la de aplicaciones. Generalmente son instalados cuando se requiere seguridad sensible al contexto y en aplicaciones muy complejas.

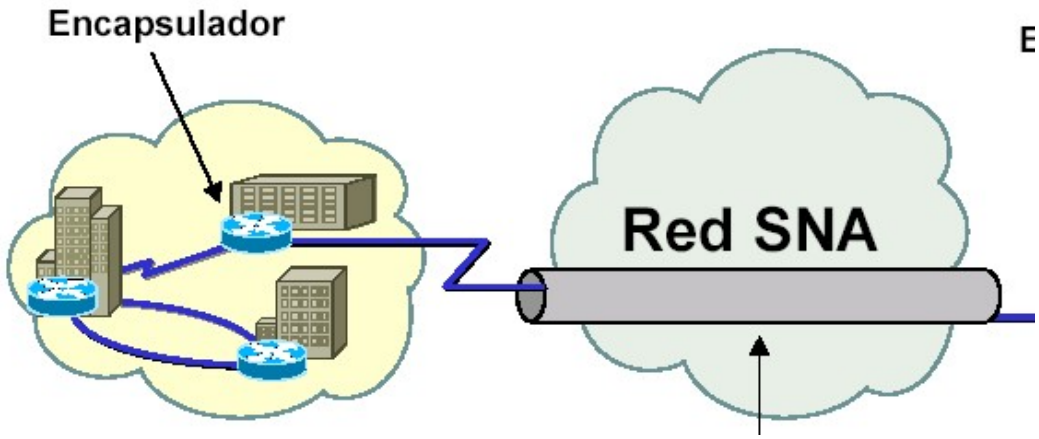
4 Redes privadas virtuales

4.1 Tunneling

4.1.1 Concepto

Se denomina "**tunneling**" al método que permite usar la infraestructura de Internet para transferir datos en forma segura desde una red sobre otra., mediante un camino lógico (túnel) a través del cual los paquetes encapsulados viajan a través de la red. Los datos a ser transferidos pueden ser tramas o paquetes de otro protocolo. En lugar de enviar la trama tal como fue generada por el nodo origen, el protocolo de "tunneling" encapsula la trama en otro encabezado adicional, el cual provee información de enrutamiento que le permite a los datos atravesar la red intermedia. De ese modo, los paquetes encapsulados son enrutados entre los extremos del túnel. Una vez que las tramas encapsuladas alcanzan su destino en la red, la trama es desencapsulada y entregada a su destino final. Se debe notar que "tunneling" es el proceso completo (encapsulado, transmisión, y desencapsulado de los paquetes).

Es decir, podemos considerar el tunneling como la transmisión de paquetes de datos de un determinado protocolo encapsulados en otro, de manera que el contenido del paquete original puede llegar inalterado a su destino, creando algo así como una conexión punto a punto virtual a través de una red.



Por regla general la información a ser transmitida, procesada y recibida mediante la implementación del túnel a través de Internet debe verificar: **integridad** (que los datos a ser transmitidos desde una fuente a su destino no puedan ser alterados); **confidencialidad** (que los datos a ser transmitidos desde una fuente a su destino sólo puedan ser conocidos exclusivamente por partes especialmente habilitadas);

autenticidad (certeza de que los datos recibidos son los mismos datos que fueron enviados y que su emisor es el que se ha declarado como tal); **no repudio** (la capacidad de probar que el emisor efectivamente envió ciertos datos y que éste no pueda negar haberlo hecho).

4.1.2 Túneles en Capas de Enlace y Red

Los protocolos PPPT y L2TP son protocolos de "tunneling" de Capa 2 que utilizan tramas como unidad de intercambio, encapsulándolas en una trama PPP ("Point-to-Point Protocol") para ser enviados a través de la red, mientras que el protocolo **IPSec** (estudiado anteriormente) es un protocolo de **"tunneling" de Capa 3** que utiliza paquetes IP encapsulándolos con un encabezado IP adicional antes de enviarlo a través de la red IP.

Las principales implementaciones de túneles sobre VPNs en estos niveles están dadas por las propuestas cursadas (RFCs, Request for Comments) a la Internet Engineering Task Force (I.E.T.F.). Estas pueden agruparse según el nivel de protocolos que usen: Túnel de Capa 3 (tal como IPSec o IP Móvil), y Túnel de Capa 2 (tal como L2TP).

4.2 Infraestructura VPN

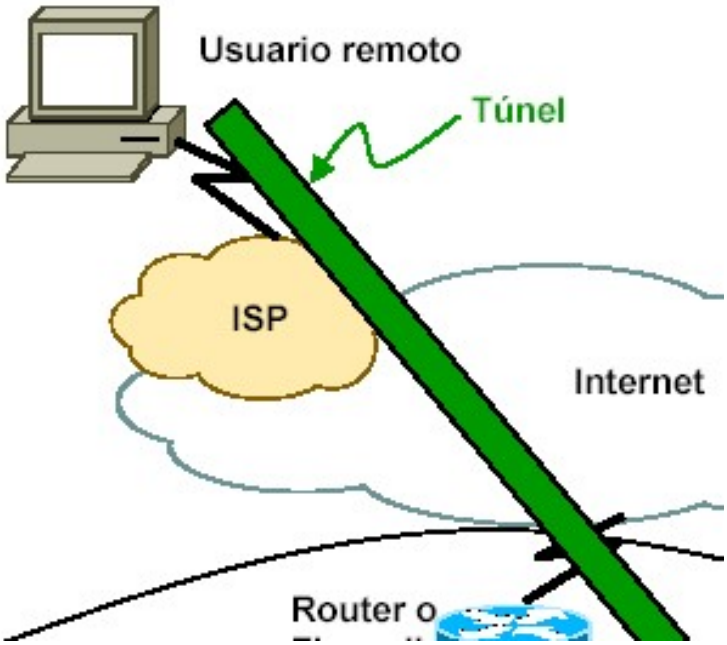
4.2.1 Introducción

Una Red Privada Virtual (VPN) es una red de información privada que hace uso de una infraestructura pública de telecomunicaciones, que conecta diferentes segmentos de red o usuarios a una red principal, manteniendo la privacidad a través del uso de un protocolo de túnel o aislamiento así como de otras tecnologías que proveen seguridad. La función principal de una VPN es la de brindar conectividad a una red, a través de una red pública, manteniendo la integridad y confidencialidad de la información.

Cuando se implementa una VPN, hay dos **aspectos fundamentales** que deben ser considerados: el **coste** y la **seguridad**. De estas dos características, la seguridad es el elemento fundamental; sin la seguridad adecuada, los riesgos pesarán más que los beneficios. Una compañía puede usar Internet para enviar archivos a otras corporaciones; sin embargo, sin medidas y políticas de seguridad adecuadas, la información queda expuesta a ataques.

En adición a los riesgos de seguridad, hay aspectos de **Calidad en el Servicio (QoS)** concernientes a Internet que se deben tratar. La calidad en el servicio se refiere al acuerdo de servicio ofrecido por un Proveedor de Servicios de Internet (ISP) a un cliente, que garantiza cierto nivel de desempeño.

Una Red Privada Virtual conecta los componentes y recursos de una red sobre otra, mediante la implementación de un túnel a través de Internet (u otra red pública), de manera que los participantes del túnel se beneficien de las condiciones de seguridad que normalmente se ofrecen en una red privada.



Una VPN permite crear un perímetro de seguridad de operación. Incorpora routers y firewalls como base, y por encima utiliza mecanismos de seguridad como son:

- Confidencialidad de la información. Realizan encriptación de datos, utilizando varias técnicas: DES, 3DES, RSA
- Integridad de la información
- Compresión de datos
- Autenticación. El servidor VPN autentica al cliente para asegurarse que tienen los permisos necesarios. Si además el cliente autentica al servidor se protege contra la suplantación de servidores.
- Administración distribuida de claves
- Tunneling para establecer las conexiones punto a punto
- Acceso desde el exterior controlado por ser acceso remoto a un servidor seguro

4.2.2 Elementos de una conexión VPN

Los elementos generales que forman parte de una VPN son los siguientes son:

- ✓ Servidor VPN: Programa servidor instalado en un ordenador que proporciona conexiones de acceso remoto VPN o conexiones enrutador-enrutador.
- ✓ Cliente VPN: Programa cliente VPN que es quien solicita al servidor las conexiones de uno u otro tipo.
- ✓ Conexión VPN: Porción de la conexión entre dos usuarios, donde se encriptan los datos. Una conexión de acceso remoto se da cuando un ordenador personal se conecta a la red privada bien para obtener los servicios del servidor o para acceder a la red completa. Una conexión enrutador-enrutador conecta dos porciones de la red privada. En ambos casos el servidor pide autenticación del cliente. La autenticación puede ser mutua.

- ✓ Túnel: El fragmento de conexión que está dentro de la red VPN de la organización, en el cual se encapsulan los datos para que al salir a la red IP viajen seguros hasta su destino. Estos datos pueden estar encriptados o no.
- ✓ Protocolos de Túnel: Puede ser cualquiera de los enumerados anteriormente.
- ✓ Datos de túnel: Datos a enviar.
- ✓ Red de tránsito: La red IP intermedia que se emplea para enviar los datos. Puede ser Internet o una red Intranet IP privada que hayamos alquilado.

4.2.3 Funcionamiento general de una VPN

El funcionamiento general de una VPN es el siguiente:

1. El usuario remoto marca a su ISP local y se conecta a la red del ISP de forma normal
2. Cuando desea conectarse a la red corporativa, el usuario inicia el túnel mandando una petición a un servidor VPN de la red corporativa
3. El servidor VPN autentica al usuario y crea el otro extremo del túnel
4. El usuario comienza a enviar datos a través del túnel, que son cifrados por el software VPN (del cliente) antes de ser enviados sobre la conexión del ISP
5. En el destino, el servidor VPN recibe los datos y los descifra, propagando los datos hacia la red corporativa. Cualquier información enviada de vuelta al usuario remoto también es cifrada antes de enviarse por Internet

5 Medidas específicas para las comunicaciones móviles

5.1 Seguridad en redes 5G

Las redes de comunicaciones móviles 5G empiezan a desplegarse poco a poco por todo el mundo. Esta generación de sistema de telecomunicaciones tiene como objetivo entregar:

- Banda ancha móvil mejorada
- Comunicaciones masivas entre dispositivos y máquinas
- Comunicaciones ultra confiables y de baja latencia

El propósito es ser más rápido, más fiable y ser capaz de administrar todo el conjunto de dispositivos previsto para el Internet móvil de las cosas. Todo ello permitiendo la transformación digital de nuestra sociedad, los procesos de negocio y la fabricación.

Para habilitar esto, las redes 5G ofrecerán la ejecución de múltiples redes lógicas en una única infraestructura física común, con múltiples niveles de servicios y capacidades de red de múltiples conectividades. Para permitir la flexibilidad, agilidad y economías de escala requeridas, estas tecnologías se entregarán a través de entornos virtuales y de contenedores.

Desde el punto de vista de la seguridad, las redes 5G se han diseñado para abordar muchas de las amenazas que enfrentan las redes 4G / 3G / 2G actuales. Los controles de seguridad incluyen nuevas capacidades de autenticación mutua, protección mejorada de la identidad del suscriptor y mecanismos de seguridad adicionales. 5G ofrece a la industria móvil una oportunidad para elevar los niveles de seguridad de la red y del servicio.

5G proporciona medidas preventivas para limitar el impacto a las amenazas conocidas, pero la adopción de nuevas tecnologías de red introduce nuevas amenazas potenciales que la industria debe manejar.

Algunos de los controles de seguridad de la era 5G, se mencionan a continuación.

Seguridad por diseño

El desarrollo de estándares 5G ha adoptado los principios de "Seguridad por diseño", lo que implica las siguientes cuestiones:

- Las redes 5G hacen uso de la autenticación mutua: El remitente y el receptor, una vez confirmados mutuamente, tienen un nivel de confianza establecido y la relación de extremo a extremo está asegurada
- Se presupone que la red es "abierta": Se elimina cualquier suposición de seguridad de los productos o procesos superpuestos
- La aceptación de que todos los enlaces podrían ser explotados: Se establece el cifrado obligatorio del tráfico inter / intra - red, asegurando que la información cifrada no tenga valor cuando es interceptada

Aunque esta es una práctica común en soluciones para otros servicios, como la banca en línea, es un cambio de paradigma importante para las prácticas de telecomunicaciones móviles existentes. Como consecuencia, las redes 5G deberían brindar al consumidor más protección que las redes 4G / 3G / 2G existentes.

Modelo de implementación 5G

Los estándares 5G describen una serie de modelos de implementación. Aunque hay planes para implementar al menos cinco opciones adicionales en el futuro, la única opción que se está implementando actualmente es el llamado modo no autónomo (NSA – Non Stand Alone). Aquí es donde las estaciones base 5G se integran con una red 4G existente que funciona en conjunto con las estaciones base LTE y se conectan al núcleo LTE, basándose en las medidas y protecciones que proporciona el núcleo LTE.

La próxima fase de implementación de 5G probablemente será el modo Stand Alone (SA), más precisamente SA-NR, que consiste en una nueva red de radio 5G (NR) conectada a una red central 5G (5GC). El cambio a un núcleo 5G permitirá realizar todas las características de seguridad de las especificaciones 5G. Aunque se reconoce que los nuevos paradigmas (arquitectura nativa en la nube, basada en servicios) introducirán nuevos desafíos de seguridad.

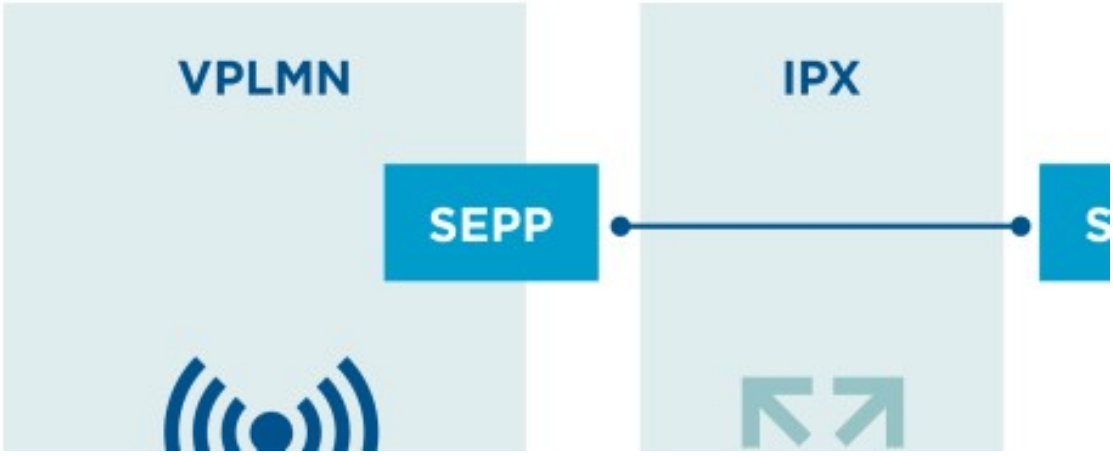
Protección del suscriptor y del dispositivo

Las redes 5G mejoran la confidencialidad e integridad de los datos del usuario y del dispositivo. A diferencia de las generaciones anteriores de sistemas móviles, las redes 5G:

- Protegen la confidencialidad de los mensajes iniciales que utilizan el protocolo NAS (Non-access stratum) entre el dispositivo y la red. Como resultado, ya no es posible rastrear el equipo de usuario utilizando las metodologías de ataque actuales a través de la interfaz de radio: se establece protección contra ataques de hombre en el medio (man in the middle) y estación base falsa.
- Introduce un mecanismo de protección llamado control en la red propia (home). Esto significa que la autenticación final del dispositivo a una red visitada se completa después de que la red propia haya verificado el estado de autenticación del dispositivo en la red visitada. Esta mejora evitará varios tipos de fraude en itinerancia que han sufrido históricamente los operadores y respaldará el requisito del operador de autenticar correctamente los dispositivos.
- Admite autenticación unificada en otros tipos de redes de acceso, como por ejemplo WLAN, lo que permite que las redes 5G administren conexiones previamente no administradas y no seguras. Esto incluye la posibilidad de realizar una nueva autenticación del equipo de usuario cuando se mueve entre diferentes redes de acceso o de servicio.
- Introduce la verificación de integridad en el plano del usuario, asegurando que el tráfico del usuario no se modifique durante el tránsito.
- Mejora la protección de la privacidad con el uso de pares de claves públicas / privadas, que permiten ocultar la identidad del suscriptor y derivar las claves utilizadas en toda la arquitectura del servicio.

Protección de red

Las redes 5G presentan un nuevo elemento de arquitectura de red: el Security Edge Protection Proxy (SEPP). El SEPP protege el borde de la red doméstica, actuando como puerta de enlace de seguridad (Gateway de seguridad) en las interconexiones entre la red propia y las redes visitadas.



El SEPP está diseñado para:

- Proporcionar seguridad en la capa de aplicación y proteger contra escuchas y ataques de repetición.
- Proporcionar autenticación de extremo a extremo, integridad y confidencialidad mediante firmas y cifrado de todos los mensajes itinerantes vía HTTP.
- Ofrecer mecanismos de administración de claves para establecer las claves criptográficas requeridas y realizar los procedimientos de negociación de las capacidades de seguridad.
- Realizar filtrado de mensajes y vigilancia, ocultación de topología y validación de objetos JSON; incluida la verificación de información entre capas con información de dirección en la capa IP.

Nueva pila de protocolos de TI

Históricamente, las redes de operadores han utilizado principalmente protocolos propietarios para la gestión de redes. Las redes 5G se trasladan a una pila de protocolos basada en IP, lo que permite la interoperabilidad con una mayor cantidad de servicios y tecnologías en el futuro. Los siguientes protocolos, esquemas y procesos se adoptarán en 5G:

- HTTP / 2, que reemplaza a Diameter
- TLS como una capa adicional de protección que proporciona comunicación cifrada entre todas las funciones de red dentro de una red móvil pública
- TCP como el protocolo de la capa de transporte como reemplazo del protocolo de transporte SCTP.
- RESTful con OpenAPI 3.0.0 como lenguaje de definición de interfaz (IDL)



Como estos protocolos se utilizan ampliamente en la industria de TI, su uso probablemente:

- Conduzca a un mayor impacto de las vulnerabilidades ubicadas dentro de estos protocolos.
- Amplia el grupo potencial de atacantes. Las redes centrales 4G y especialmente 3G se benefician de que los atacantes tienen poca experiencia con los estándares de propiedad que utilizan.

Los informes de vulnerabilidad que emplea GSMA deberán incluir el alcance de las vulnerabilidades descubiertas en estos protocolos. Una vez ubicados, el tiempo para reparar las vulnerabilidades relevantes debería ser corto.

Tecnologías soportadas en 5G

Virtualización

La arquitectura de red 5GC estará basada en el servicio, lo que significa que las operaciones de la red central se pueden realizar a través de funciones fuera de la red del operador, como por ejemplo en la nube. Este es un cambio importante respecto de los controles de seguridad establecidos en el core de la red, sin embargo, ofrece al operador la oportunidad de aprovechar las tecnologías de virtualización.

Con esta oportunidad aparecen nuevos vectores de amenazas que gestionar. Deben considerarse los controles de virtualización tradicionales, incluido el aislamiento de recursos en proveedores de cloud. Los controles de aislamiento adecuados reducen el riesgo de fuga de datos y el impacto de los ataques de malware sobre las tecnologías de virtualización. Vulnerabilidades ocurridas a nivel de microprocesador (como por ejemplo los casos de Spectre y Meltdown) han resaltado que el aislamiento de recursos dentro de un entorno virtual en proveedores de cloud no garantiza la seguridad absoluta, pero sí puede minimizar los ataques.

El establecimiento de contenedores es una tecnología de virtualización a nivel de sistema operativo que está ganando terreno. El sistema operativo host restringe el acceso del contenedor a los recursos físicos, como CPU, almacenamiento y memoria, por lo que un solo contenedor no puede consumir todos los recursos físicos de un host. Por lo tanto, reduce el impacto de los ataques de disponibilidad contra la plataforma.

La red definida por software brinda a los operadores la oportunidad de virtualizar sus flujos de red, lo que lleva a una simplificación del hardware.

Todas las tecnologías de virtualización permiten la segmentación de la red y el aislamiento de los recursos, lo que garantiza la seguridad y reduce el impacto de posibles ataques con éxito. La configuración de estos servicios debe llevarse a cabo con un principio de seguridad en el diseño para garantizar que la protección ofrecida no sea contrarrestada por malos procesos de gestión y orquestación.

El sistema de control central, a menudo el hipervisor, actúa como el órgano director de las tecnologías virtualizadas. Como tal, la protección de esta tecnología subyacente debe ser alta. Se debe completar el modelado de amenazas específicas para ataques y vulnerabilidades propias de la virtualización.

Servicios en la nube

Las redes 5G están basadas en servicios virtualizados, de manera que la nube es un habilitador clave de 5G. La arquitectura 5G ha sido diseñada para ser nativa en la nube, ya que aporta elasticidad y escalabilidad.

Según Mobile World Live, 5G permite a los operadores exponer servicios enriquecidos a través de la nube y las API de Restful. Se deben seguir prácticas de codificación seguras para garantizar que los datos no se filtren y que el código no se pueda utilizar para explotar la red del proveedor u operador de la nube.

Segmentación de red

La segmentación de red permite al operador personalizar el comportamiento de la red, adaptando (segmentando) la red para atender casos de uso específicos utilizando el mismo hardware. GSMA ha definido distintos atributos que caracterizan un segmento de red en su documentación de referencia.

El modelo de seguridad para cada segmento debe adaptarse al caso de uso. Se pueden prever diferentes niveles de aislamiento que abarcan desde un solo nodo de la red central hasta el acceso de radio totalmente dedicado. Cada tipo de aislamiento se debe integrar en la fase de diseño. Por ejemplo, un segmento de red para cirugía remota debe considerar la identificación y autorización mutua constante para detener las amenazas del tipo “man in the middle”, pero un segmento para la gestión de contenido de realidad ampliada o con realidad virtual no requerirá el mismo nivel de seguridad.

IoT móvil

Aunque el IoT ya es frecuente en las redes 2G / 3G / 4G, el número de conexiones IoT aumentará exponencialmente en 5G. Un número mucho mayor de conexiones no significa que los controles de seguridad deban cambiar significativamente, sin embargo, sí deben escalar. El IoT necesita ser codificado, implementado y administrado de manera segura durante todo su ciclo de vida. La mayoría de los servicios de IoT comparten una arquitectura común y, como tal, los ataques a los que estará sujeto cada servicio probablemente encajen en tres escenarios de ataque comunes:

- Ataques en los dispositivos (puntos finales) a través de las aplicaciones que se ejecutan en el dispositivo, ataques remotos desde Internet y ataques físicos.
- Ataques en plataformas de servicio (por ejemplo, en la nube)
- Ataques en los enlaces de comunicaciones (por ejemplo, WLAN, interfaz aérea, etc.)

En el lado de salida, los dispositivos IoT se aprovechan cada vez más para lanzar ataques DDoS a medida que cada dispositivo crea algún tipo de datos. Dado que el número de dispositivos es cada vez más elevado, significa que cada vez hay más ataques basados en el volumen (ataques de denegación de servicio distribuido).

eSIM

Una eSIM elimina la necesidad de una tarjeta SIM extraíble en el dispositivo móvil. En su lugar, los datos de esa tarjeta se preparan en una plataforma remota de

aprovisionamiento de SIM y luego se descargan en forma de perfil eSIM a través de HTTPS en un elemento seguro (eUICC) permanentemente embebido en el dispositivo móvil.

Este elemento seguro, identificado por un identificador electrónico único a nivel mundial, puede almacenar muchos perfiles, y cuando se habilita un perfil, los datos en ese perfil se utilizan para identificar y autenticar al suscriptor en la red móvil de la misma manera que lo haría una tarjeta SIM extraíble.

El sistema utiliza certificados de infraestructura de clave pública (PKI) que permiten que la plataforma remota de aprovisionamiento de SIM y el elemento seguro en el terminal se autentiquen mutuamente. Todas las claves se generan con Secreto Perfecto hacia delante.

La gestión de los perfiles eSIM en el elemento seguro en el terminal la lleva a cabo el usuario final en el caso de uso de una persona física, o una plataforma remota de aprovisionamiento de SIM en el caso de uso de M2M / IoT.

Inteligencia Artificial

Aunque es un término general para muchas tecnologías, se espera que la inteligencia artificial se emplee ampliamente en redes 5G y una de las aplicaciones sería mejorar la seguridad. Los operadores deben aprovechar Machine Learning (ML) y Deep Learning (DL) para automatizar la detección de amenazas y fraudes.

El uso de inteligencia artificial es particularmente relevante cuando se consideran los volúmenes de datos que generarán las redes 5G. La inteligencia artificial puede ser una forma más factible de mitigar ataques desconocidos en tiempo real. La inteligencia artificial también se puede usar para impulsar redes de autocuración en las que el sistema puede identificar problemas y tomar medidas automatizadas para proporcionar la solución.

Sin embargo, esta tecnología también está disponible para el atacante y se anticipan ataques impulsados por inteligencia artificial.

5.2 Medidas concretas de seguridad

A continuación se exponen una serie de medidas concretas relacionadas con la seguridad de las comunicaciones móviles:

Privacidad, cifrado e integridad:

En LTE existen las siguientes medidas:

- Cifrado en la ruta de radio entre la estación móvil y la estación base LTE
- Cifrado e integridad del plano de control entre el equipo del usuario y la entidad de gestión de movilidad
- algoritmos de 128 bits compatibles

Y en redes 5G se proponen, además, las siguientes:

- Soporte actual de algoritmos de 256 bits propuestos para futuras versiones

- Integridad implementada que previene el cambio no autorizado de los datos del usuario.

Autenticación:

En LTE existen las siguientes medidas:

- Clave compartida aprovisionada en la UICC y la AUSF (Función del servidor de autenticación) en la red.
- Esto proporciona autenticación mutua entre el UE y la red.

Y en redes 5G se proponen, además, las siguientes:

- Autenticación utilizando el framework de autenticación EAP
- 5G-AKA y EAP-AKA compatibles con tecnologías de acceso 3GPP y no 3GPP.
- Protege la confidencialidad de los mensajes iniciales de acceso NAS entre el dispositivo y la red.
- Permite volver a autenticar el dispositivo del usuario cuando se mueve entre diferentes redes de acceso o incluso entre redes de servicio sin tener que ejecutar la autenticación completa.

Identificador permanente del suscriptor (SUPI) (Antiguo IMSI)

En LTE existen las siguientes medidas:

- Identificador enviado en texto sin formato antes de la autenticación de red

Y en redes 5G se proponen, además, las siguientes:

- El identificador oculto de suscripción (SUCI) proporciona un mecanismo para usar la clave pública de la red local para cifrar el identificador de suscriptor (IMSI). Proteger la confidencialidad de los mensajes iniciales de acceso NAS entre el dispositivo y la red.

Control en la red propia del operador

En LTE no existían medidas de seguridad. En cambio, en redes 5G, existe la siguiente medida:

- La HPMN (Home Public Mobile Network) puede verificar que el dispositivo del usuario está presente y solicita servicio de una VPMN (Visited Public Mobile Network), lo que es útil en escenarios de roaming y prevención de fraude.

Security Edge Proxy Protection (SEPP)

En LTE no existía proxy de protección. En cambio, en redes 5G, sí que existe dicho proxy:

- El SEPP protege el borde de la red local, actuando como puerta de enlace de seguridad en las interconexiones entre la red doméstica y las redes visitadas.

6 Amenazas lógicas

Se pueden señalar cuatro categorías habituales de formas de amenazas lógicas:

- Denegación del servicio (Interrupción)
- Intercepción (escucha o monitorización)
- Suplantación (impostura o fabricación)
- Modificación (manipulación o alteración)

Los ataques o amenazas más habituales más habituales de cada una de las categorías son los siguientes:

6.1 Denegación de servicio (Interrupción)

En general consisten en saturar los recursos del equipo hasta que éste sea incapaz de seguir prestando sus servicios, mediante consumo de recursos, alteración de configuraciones o alteración de componentes de red. También cuando una tercera parte impide que una comunicación se establezca, evitando que los datos del emisor lleguen al receptor.

Son amenazas que atentan contra la disponibilidad del sistema y la autenticación (caso de suplantación).

Algunos conceptos generales relacionados con la interrupción son los siguientes:

DoS (denial of service): También se conoce como jamming o flooding. Consiste en el consumo de recursos limitados, escasos o no renovables: ancho de banda, memoria, espacio en disco, tiempo de CPU, acceso a otras máquinas, nº máximo de conexiones, etc. Ejemplos: ICMP, UDP, envío de gran número de mensajes, ficheros enormes, etc.

DDoS (Distribuited Denial of Service): Involucra varias máquinas. Los bots o botnet es la red de máquinas a disposición de un atacante y la máquina zombi es una máquina atacada a la que se introduce un malware que nos hace dominarla (está a nuestro merced). Es un ataque bajo control de una maestra, permite consumir más fácilmente recursos de una víctima como el ancho de banda al utilizar una red de zombies. Ejemplo: ataque de fuerza bruta mediante el uso de muchos zombis que van a solicitar un servicio a una victima.

DRDoS (Distribuited Reflection Denial of Service): DDoS es complicado puesto que hay que tomar el control de otras máquinas y usar un malware. Se suele utilizar como alternativa el DRDoS que consiste en utilizar otro servidor o servidores (inocentes) para generar tráfico hacia una víctima. Ejemplo: un servidor Web al que llega un SYN con IP origen falso que es la de la víctima, todas las contestaciones irán a la IP origen falsa, es decir, se satura la máquina víctima. Ejemplo: Ataque con SYN Flood.

Las amenazas más habituales relacionadas con este tipo de ataques son las siguientes:

- **Connection flood** (inundación de conexiones)

- Empresas que brindan servicios de Internet tienen un límite máximo en el número de conexiones simultáneas.
- Un atacante establece muchas conexiones y no realiza ninguna petición sobre ellas, monopolizará la capacidad del servidor.
- Las conexiones van caducando por inactividad poco a poco, pero el atacante sólo necesita intentar nuevas conexiones para mantener fuera de servicio al servidor.

- **Jamming o flooding con IP Spoofing**
  - El atacante satura el sistema con mensajes para establecer una conexión.
  - En vez de proveer la dirección IP del emisor, el mensaje contiene falsas direcciones IP usando "IP Spoofing (Suplantación de IP)".
  - El sistema responde al mensaje pero al no recibir respuesta acumula buffers con información de las conexiones abiertas, no dejando lugar a las conexiones legítimas.
- **Ping de la muerte**
  - Una versión-trampa del comando ping. Mientras que el ping normal simplemente verifica si un sistema esta enlazado a la red, el ping de la muerte causa el reboot o el apagado forzado del equipo.
  - Se basan en manipular el tamaño de paquete que se envía en el comando ping de manera que se produce el desbordamiento de memoria de la máquina atacada. Normalmente todas las máquinas tienen resuelta esta vulnerabilidad
- **eMail bombing**
  - Otra acción común es la de enviar millares de e-mails sin sentido a todos los usuarios posibles en forma continua buscando la saturación de los distintos servidores de correo de destino.
- **Smurf o broadcast storm**
  - Recolectar una serie de direcciones de Broadcast, para a continuación mandar una petición ICMP (Internet Control Message Protocol). Subprotocolo de diagnóstico y notificación de errores del Protocolo de Internet (IP). Como tal, se usa para enviar mensajes de error, indicando por ejemplo que un servicio determinado no está disponible o que un router o host no puede ser localizado. Pues bien, lo que se hace es simular un ping (ICMP), y se envía a cada una de ellas en serie falsificando la dirección IP origen donde se pondrá la dirección IP de la víctima.
  - Así cientos o miles de hosts mandarán una respuesta a la dirección IP de la víctima.
- **Supernuke o winnuke**
  - Un ataque característico (y quizás el más común) de los equipos con Windows es el Nuke, que hace que los equipos que escuchan por el puerto UDP 137 a 139 (utilizados por los protocolos Netbios de Wins),

queden fuera de servicio (o disminuyan su rendimientos) al enviarle paquetes UDP manipulados.

- Generalmente se envían fragmentos de paquetes, que la máquina víctima detecta como inválidos pasando a un estado inestable.

- **Bulos (hoaxes)**
  - Transmitir por mail la falsa existencia de un virus, esto ocasiona que se reenvíe a otros usuarios, lo que puede colapsar servidores de correo o ser usados por spammers.
- **Ransonware**
  - Cierto tipo de código dañino está diseñado para tratar de obligar a sus víctimas a pagar dinero para librarse de una infección. Este tipo de malware secuestra un ordenador mediante el cifrado de documentos y fotos, por ejemplo, que dejarán de estar accesibles. El malware indicará a la víctima que deberá pagar una cierta cantidad de dinero para eliminar el cifrado. Por lo general, la víctima no recibe ninguna solución que funcione después de que el pago ha sido satisfecho.

6.2 Intercepción (Escucha o monitorización)

Cuando una tercera parte, no autorizada, accede al contenido de la información con el objetivo de apropiarse de la misma o con otros objetivos futuros lícitos o no.

Consiste en observar a la víctima con el objetivo de obtener información, establecer vulnerabilidades y posibles formas de acceso futuras.

Son ataques contra la confidencialidad principalmente, aunque el resultado se utilice en el futuro para otro tipo de ataques.

Algunos conceptos relacionados con la intercepción son los siguientes:

- Espionaje: espiar en busca de contraseñas, normalmente pegadas con post it al monitor, un tipo especial es el trashing: buscar en la basura (tanto física como buffers, de información) contraseñas. O el Shoulder Surfing (mirar por encima del hombro) para ver cómo se teclea la contraseña.
- Decoy: falsas interfaces que simulan a la real y permiten almacenar las contraseñas introducidas.
- Scanning: escaneo de puertos abiertos para ser usados posteriormente.
- Sniffer: escucha en modo promiscuo de todos los paquetes que circulan por la red.

Algunos ataques concretos son:

- **Ataques con señuelos (decoy)**
  - Programas diseñados con la misma interfaz que otro original y que solicitan usuario y password.
- **Keyloggers**

- Otra técnica es utilizar los keyloggers que son programas que guardan todas las acciones de un usuario (las teclas pulsadas, los clicks del ratón, las ventanas activadas, los sitios visitados en Internet, los mails enviados) y luego se analiza el archivo generado para conocer login y password u otro tipo de información.

- **TCP connect scanning**
  - Esta es la forma básica del scaneo de puertos TCP.
  - Se envía el paquete SYN
  - Si el puerto está escuchando, devolverá una respuesta de éxito (paquete SYN-ACK); cualquier otro caso significará que el puerto no está abierto o que no se puede establecer conexión con él.
  - Su principal desventaja es que este método es fácilmente detectable por el Administrador del sistema.
  - Una variante es el TCP SYN Scanning. Consiste en que el cliente (atacante) envía, después del SYN-ACK del servidor, un paquete RST para terminar la conexión y registrar el puerto abierto.

- **Fragmentation scanning**
  - Es una modificación de las anteriores en la que en lugar de enviar paquetes completos de sondeo, estos se dividen en un par de fragmentos IP, partiéndose así la cabecera IP en distintos paquetes.
  - Esto hace más difícil de detectar y filtrar por los mecanismos de protección de la máquina amenazada (firewalls).

- **Eavesdropping - packet sniffing**
  - Se realiza con Packet Sniffers, que son programas que controlan los paquetes que circulan por la red.
  - Los sniffers pueden ser colocados tanto en estaciones de trabajo conectadas a la red como a un equipo Router o un Gateway de Internet y puede ser realizado por un usuario con legítimo acceso o por un intruso que ha ingresado por otras vías a las instalaciones.
  - Cada máquina conectada a la red verifica la dirección destino de los paquetes TCP. Un sniffer consiste en colocar a la placa de red en un modo llamado promiscuo, el cual desactiva el filtro de verificación de direcciones y por tanto todos los paquetes enviados a la red llegan a esta placa. Obteniéndose acceso a toda la información que circula por la red.

- **Snooping-downloading**
  - Significa obtener la información sin modificarla, como el sniffing. Sin embargo los métodos son diferentes. Aquí, además de interceptar el tráfico de red, el atacante accede a los documentos, mensajes de correo electrónico y otra información, realizando en la mayoría de los casos un downloading (copia de documentos) de esa información a su propio ordenador, para luego hacer un análisis exhaustivo de la misma.

- El Snooping puede ser realizado por simple curiosidad, pero también es realizado con fines de espionaje y robo de información o software.

6.3 Suplantación (impostura o fabricación)

La suplantación es similar a una intercepción pero con el objetivo de sustituir a una parte.

Se busca suplantar al usuario/sistema original utilizando distintas técnicas y así tener acceso a la información. Generalmente se realiza tomando las sesiones ya establecidas por la víctima u obteniendo su nombre de usuario y password mediante distintos mecanismos.

También ocurre cuando una tercera parte no autorizada introduce mensajes propios en una comunicación para hacer creer al receptor que proceden del emisor utilizando técnicas de suplantación (spoofing).

Son ataques contra la autenticación y confidencialidad, principalmente.

Algunos conceptos generales relacionados con este tipo de ataques son los siguientes:

- **Spoofing o falsificación:**
  - El intruso oculta su identidad real, haciéndose pasar por otro usuario, equipo o aplicación.
  - Para ello se realiza tanto la modificación de paquetes existentes en la red como la creación de nuevos cuyo objeto sea falsear la identidad de algún componente de la transmisión de un mensaje o del sistema en su conjunto.
  - En sentido genérico, el spoofing o falsificación se puede hacer: de dirección IP, sitios Web, DNS, mail, etc.
- **Hijacking**
  - Significa "Secuestro" en inglés y en el ámbito informático hace referencia a toda técnica ilegal que lleve consigo el adueñamiento o robo de algo (generalmente información) por parte de un atacante, es por tanto un concepto muy abierto y que puede aplicarse a varios ámbitos, de esta manera podemos encontramos con el adueñamiento o secuestro de conexiones de red, sesiones de terminal, servicios, navegadores, etc.

Algunos ataques concretos son los siguientes:

- **IP splicing-hijacking**
  - Se produce cuando un atacante consigue interceptar una sesión ya establecida. El atacante espera a que la victima se identifique ante el sistema y tras ello le suplanta como usuario autorizado.
  - El atacante que ha visto, mediante un Sniffer, los paquete que circularon por la red calcula el número de secuencia siguiente para continuar con la comunicación.
- **Browser hijacking**

- Secuestro del navegador. Se llama así al efecto de apropiación que realizan algunos programas sobre el navegador web lanzando popups, modificando la página de inicio, modificando la página de búsqueda predeterminada, etc.

- **Man In The Middle**
  - El intruso usa una aplicación para simular el comportamiento del cliente o del servidor, o bien intercepta los paquetes de información por la red pudiendo visionarlos y modificarlos a su antojo.
  - Como consecuencia el servidor o cliente creen estar comunicándose con el equipo legítimo, cuando en realidad se trata del equipo del atacante, que aparece a todos los efectos como el destino auténtico.

- **IP spoofing**
  - El atacante genera paquetes de Internet con una dirección IP de red falsa en el origen, pero que es aceptada por el destinatario del paquete.
  - Paquetes manipulados con la dirección de un tercero de forma que la víctima "ve" un ataque proveniente de ese tercero y no la dirección real del atacante.
  - Desde su equipo, un pirata simula la identidad de otra máquina de la red para conseguir acceso a recursos de un tercer sistema que ha establecido algún tipo de confianza basada en el nombre o la dirección IP del equipo suplantado.

- **Spoofing-looping**
  - Una forma común de "Spoofing" es conseguir el nombre y password de un usuario para, una vez entrado al sistema, tomar acciones en nombre de él.
  - El intruso usualmente utiliza este primer sistema para obtener información y acceder a un segundo sistema y luego utiliza este para entrar en un tercero y así sucesivamente. Este proceso llamado "Looping", tiene la finalidad de ocultar la identificación y ubicación del atacante.
  - De esta manera se oculta la verdadera procedencia de un atacante, llegando incluso a provocar graves incidentes si la organización atacada cree que proviene de otra organización.

- **Web spoofing**
  - El atacante crea un sitio web completo (falso) similar al que la víctima desea entrar. Los accesos a este sitio están dirigidos por el atacante permitiéndole controlar todas las acciones de la víctima, desde sus datos hasta las passwords, número de tarjetas de crédito, etc. No confundir con phising.

- **DNS spoofing (pharming)**
  - Suplantación de identidad por nombre de dominio. Se trata del falseamiento de una relación "Nombre de dominio-IP" ante una consulta

de resolución de nombre, es decir, resolver con una dirección IP falsa un cierto nombre DNS o viceversa. Esto se consigue falseando las entradas de la relación Nombre de dominio-IP de un servidor DNS, mediante alguna vulnerabilidad del servidor en concreto o por su confianza hacia servidores poco fiables. Las entradas falseadas de un servidor DNS son susceptibles de infectar (envenenar) el caché DNS de otro servidor diferente (DNS Poisoning).

- **Mail Spoofing**
  - Suplantación en correo electrónico de la dirección e-mail de otras personas o entidades. Esta técnica es usada con asiduidad para el envío de e-mails hoax (bulos) como suplemento perfecto para el uso de phising y para SPAM
- **Ingeniería social**
  - Manipulación de las personas para conseguir que digan o hagan algo que beneficie al atacante (sirven para conseguir contraseñas y acceso a redes)
  - Ejemplos:
    - Aplicación adicional a los virus. Por ejemplo darle un nombre que incite a la víctima a ejecutar el archivo que viaja en el mail (virus I love you) o como si se tratara de un falso parche antivirus.
    - Phishing: a través del mail se envían links a páginas webs que se hacen pasar por bancos o tiendas virtuales con el objeto de capturar la password o número de cuenta de la víctima.
    - Timos (scams): timos varios que prometen dinero,... pero vía mail.

6.4 Modificación (manipulación)

Cuando una tercera parte no autorizada accede al contenido de la información y la modifica de forma que los datos que llegan al receptor de la misma difieren de los originales.

Se trata de una amenaza, principalmente contra la integridad y disponibilidad

Conceptos relacionados con ataques de modificación de la información son los siguientes:

- **El Tampering o data diddling:**
  - Modificación desautorizada de los datos o el software instalado en el sistema víctima incluyendo borrado de archivos.
  - Son particularmente serios cuando el que lo realiza ha obtenido derechos de administrador, con la capacidad de ejecutar cualquier comando
- **Ataques contra vulnerabilidades de diseño:**

- Muchos sistemas están expuestos a “agujeros” de seguridad que son explotados para acceder a archivos, obtener privilegios o realizar sabotaje.
- Estas vulnerabilidades ocurren por varias razones y miles de “puertas invisibles” son descubiertas cada día en sistemas operativos, aplicaciones de software, protocolos de red, exploradores de Internet, correo electrónico y toda clase de servicios informáticos disponibles.

- **Los Malware**
  - Término inglés “Malicious Software” o badware. Se refiere a todo software diseñado para realizar acciones maliciosas o distintas al proceso habitual de información.
  - Una clasificación habitual del Malware:
    - Virus: término genérico que comprende virus, troyanos, gusanos y bombas lógicas.
    - Código móvil malicioso: código escrito para hacer daño pero que no encaja exactamente en las clasificaciones anteriores: Applets, Active X, SQL Inject y programas en Javascript o VisualBasic script

Normalmente se utiliza el término genérico Virus para referirnos a cualquier código malicioso o malware, sin embargo interesa diferenciar cada término en función de cómo accede a un sistema (infecta), tipo de acciones que realiza y cómo se propaga. En este sentido, se diferencian en los siguientes apartados: virus, gusanos, troyanos y bombas lógicas:

- **Virus**
  - Bajo este término se englobarían todas aquellas amenazas que no entran dentro de otras categorías como código móvil malicioso, troyano, gusano o bomba lógica.
  - Suelen tener dos características: propagación y destrucción, aunque esta segunda no es imprescindible.
  - Algunos virus eliminan archivos, otros sólo muestran mensajes molestos, bromas, bloqueo de accesos, robo de datos, corromper el sistema, dañar el equipo, etc.
  - Clasificación según el modo de infección:
    - Infección de archivos: infectan archivos ejecutables con extensión .exe, .com, .bat Se les llama por eso virus parásitos Se extienden a otros archivos. El sistema operativo verá el virus como parte del programa que se está ejecutando y le asignará los mismos privilegios. Esto le permitirá infectar otros archivos, cargarse en memoria o realizar cualquier otra fechoría.
    - Infección sector arranque: fueron los primeros en aparecer, infectan el sector de arranque de discos duros y otros dispositivos de almacenamiento. Quedan residentes en memoria.

        - Multipartitos: infectan el sector de arranque y el sistema de archivos.
        - Macros: aprovecha las capacidades de automatización mediante macros de los programas de ofimática como Word, Excel,.. para infectar sus archivos. Se propaga junto al documento por lo que se extienden rápidamente.

- **Gusanos (Worms)**
    - Se caracterizan en que se propagan de sistema en sistema de manera masiva. Crean copias exactas de ellos mismos. Su principal misión es reproducirse y extenderse al mayor número de ordenadores posibles
    - Internet y el correo electrónico han supuesto el verdadero auge de este tipo de código malicioso, que pueden infectar miles de ordenadores en cuestión de horas. Su mecanismo de distribución suele ser en la mayoría de los casos muy simple. Camuflados en un mensaje aparentemente inocente, llegan a nuestro correo electrónico. Una vez ejecutado leen nuestra lista de contactos (libreta de direcciones o Address Book) y se reenvían de forma automática a todas las direcciones que contengan.
    - También pueden utilizar otro archivo para propagarse, como un Word, enviando copias de sí mismo por email; o explotar agujeros de seguridad en los sistemas para saltar de máquina en máquina. Estos son más devastadores pues no dependen de que un usuario abra o no un mensaje del correo.
    - Ejemplos Core Red, Blaster
- **Troyanos**
    - Un caballo de Troya es un programa que en su ejecución realiza tareas no previstas de antemano. El usuario ejecuta lo que cree un programa normal, permitiendo al troyano realizar tareas ocultas y, a menudo, malignas.
    - Una vez instalado parece realizar una función útil (aunque cierto tipo de troyanos permanecen ocultos y por tal motivo los antivirus o anti-troyanos no los eliminan) pero internamente realiza otras tareas de las que el usuario no es consciente, de igual forma que el Caballo de Troya que los griegos regalaron a los troyanos.
    - Este malware puede tener muchos fines: destrucción de archivos, registrar la actividad del usuario o instalar una puerta trasera para el control remoto del equipo de la víctima.
    - Uno de los caballos de Troya más sofisticados en la actualidad es el RAT (Remote Access Trojan) que permiten un control absoluto de las máquinas asaltadas. Debido al uso cada vez más generalizado de Internet con ADSL donde las máquinas están continuamente conectadas, este troyano cada vez está más extendido. Uno de los usos es tomar el control de varias máquinas de la red a través de un RAT para, por ejemplo, atacar a otra máquina de la red.

- **Bombas Lógicas**
  - Código malicioso que permanece dormido o latente hasta que se produce el evento programado para despertarlos, por ejemplo en una fecha determinada o una combinación de teclas
  - El código no suele replicarse.
  - Un ejemplo es el de un empleado que se le va a despedir y que prepara una bomba lógica para actuar cuando ya no esté en la compañía.
  - Son muy difíciles de detectar por los antivirus.